

EL KİTABI

Active Directory Güvenliği El Kitabı

Sıfırdan Uzmanlığa: Tier Modeli Merkezli Kurumsal AD Savunma
Rehberi

Uğur KARAKOÇ

Senior Cyber Security Expert

SÜRÜM 1.0 · TIER MODELİ MERKEZLİ AD GÜVENLİK REHBERİ

Yayın Bilgileri

Alan	Değer
Yazar	Uğur KARAKOÇ – Senior Cyber Security Expert
Sürüm	1.0
Kapsam	Active Directory (on-prem), Hybrid Entra ID sınır noktaları
Hedef Kitle	AD yöneticileri, güvenlik mühendisleri, pentester/red team, SOC analistleri, CISO/BT yöneticileri
Yaklaşım	Zero-to-Hero – kavramdan operasyonel uygulamaya
Çekirdek Çerçeve	Microsoft Tier Modeli (Tier 0 / 1 / 2) ve ESAE ilkeleri

Önsöz

Active Directory, 20 yılı aşkın süredir kurumsal kimlik altyapısının omurgasıdır ve tam da bu nedenle saldırganların en çok hedeflediği sistemdir. Fidyeye yazılımı operasyonlarının neredeyse tamamı, başlangıç erişiminden sonraki ilk saatlerde AD'yi hedef alır – çünkü AD'yi ele geçirmek, ortamın tamamını ele geçirmek anlamına gelir.

Bu el kitabı, AD güvenliğini iki ekseninde ele alır:

- Saldırı yüzeyini anlamak** – Kerberos, ACL, delegasyon, AD CS, GPO ve trust ilişkileri üzerinden AD'nin nasıl kırıldığını teknik detayla göstermek.
- Savunmayı yapılandırmak** – bu saldırı yüzeyini daraltacak, ölçülebilir ve uygulanabilir kontrolleri Tier Modeli etrafında organize etmek.

Rehberin omurgası **Tier Modeli**dir (Bölüm 3). Diğer tüm bölümler – Kerberos'tan AD CS'e, GPO'dan izlemeye kadar – bu modele referans verir; çünkü pratikte AD güvenliğinin başarısı tek tek zafiyetleri kapatmaktan değil, **ayrıcılık sınırlarını doğru çizmekten** geçer.

Araştırma Yöntemi ve Kaynak Politikası

Bu rehberdeki teknik içerik üç kaynak sınıfına dayanır:

- Birincil kaynaklar:** Microsoft resmi dokümantasyonu (Learn/Docs), MITRE ATT&CK, NIST SP 800-53/800-63.

- **Topluluk arařtırması:** SpecterOps (BloodHound, ADCS arařtırmaları), Sean Metcalf (ADSecurity.org), Will Schroeder & Benjamin Delpy'nin (Mimikatz, Rubeus) açık yayınları.
- **Saha deneyimi:** Gerçek pentest/red team bulgu kalıpları, PingCastle/Purple Knight benzeri denetim araçlarının kontrol kataloglarıyla çapraz doğrulanmıştır.

Saldırı tekniğı açıklamaları yalnızca **yetkili güvenlik testleri ve savunma amaçlı** kullanım için yazılmıştır.

Rol Bazlı Okuma Yolları

Rolünüz	Öncelikli Bölümler
AD Yöneticisi (yeni başlayan)	1 → 3 → 8 → 11 → 14
Güvenlik Mühendisi / Blue Team	2 → 3 → 4 → 5 → 12 → 13
Pentester / Red Team (yetkili)	2 → 4 → 5 → 6 → 7 → 9
CISO / BT Yöneticisi	2 (özet) → 3 → 14
SOC Analisti	4 → 5 → 12

İçindekiler

1. AD Temelleri
2. Tehdit Modeli & Saldırı Yüzeyi
3. Tier Modeli 0/1/2
4. Kerberos Saldırıları & Savunma
5. ACL/DACL Kötüye Kullanımı
6. AD CS / ESC1-14
7. Delegasyon (Constrained/Unconstrained/RBCD)
8. GPO Güvenliğı
9. Trust'lar & Forest Sınırları
10. Kimlik Bilgisi Hijyeni & PAM/JIT
11. g/MSA, LAPS, Servis Hesapları
12. İzleme & Tespit (SIEM/Sigma)
13. Backup & Felaket Kurtarma
14. Olgunluk Yol Haritası (Zero-to-Hero)

Kısaltmalar Listesi

Kısaltma	Açılım
AD	Active Directory
ADCS	Active Directory Certificate Services
ACL/DACL	Access Control List / Discretionary ACL
DA	Domain Admins
EA	Enterprise Admins
DC	Domain Controller
DCSync	Domain Controller Sync (replikasyon izinleri üzerinden hash çekme tekniği)
ESAE	Enhanced Security Admin Environment
gMSA/sMSA	(Group) Managed Service Account
GPO/GPP	Group Policy Object / Group Policy Preferences
JIT/JEA	Just-In-Time / Just-Enough-Administration
KRBTGT	Kerberos Ticket Granting Ticket hesabı
LAPS	Local Administrator Password Solution
PAM/PIM	Privileged Access Management / Privileged Identity Management
PAW	Privileged Access Workstation
RBCD	Resource-Based Constrained Delegation
SPN	Service Principal Name
TGT/TGS	Ticket Granting Ticket / Ticket Granting Service

Bölüm 1 — AD Temelleri

Giriş

Active Directory (AD), Windows tabanlı kurumsal ortamlarda kimlik, kimlik doğrulama ve merkezi ilke yönetimini sağlayan dizin servisi. Bu bölüm, sonraki tüm bölümlerin üzerine inşa edileceği kavramsal ve mimari zemini kurar. Tier Modeli'ni (Bölüm 3) anlamak için AD'nin nasıl yetki devrettiğini; Kerberos saldırılarını (Bölüm 4) anlamak için ise kimlik doğrulama akışının nasıl işlediğini bilmek zorunludur.

Öğrenme Hedefleri

- Forest, domain, OU, site kavramlarını ve aralarındaki güven/izolasyon sınırlarını ayırt edebilmek.
- AD objelerinin (user, computer, group, GPO) temel özelliklerini ve bunların güvenlik açısından anlamını bilmek.
- Multi-master replikasyonun (USN, tombstone, linked-value replication) çalışma mantığını kavramak.
- FSMO rollerinin her birinin güvenlik etkisini tanımlayabilmek.
- LDAP, Kerberos, DNS'in AD içindeki rollerini ve birbirleriyle ilişkisini özetleyebilmek.

Temel Kavramlar

Forest, AD'nin en üst güvenlik sınırıdır — şema, yapılandırma bölümü ve Enterprise Admins/Schema Admins grupları forest genelinde geçerlidir. Bir forest içindeki tüm domain'ler şemayı ve yapılandırmayı paylaşır; bu da forest'i **gerçek güvenlik sınırı**, domain'i ise sadece **idari sınır** yapar. Bu ayrım, Tier Modeli'nin neden domain değil forest seviyesinde düşünülmesi gerektiğinin temelidir.

Domain, kendi güvenlik ilkesine (parola/kilitlenme politikası — fine-grained password policy hariç), kendi KRBTGT hesabına ve kendi Domain Admins grubuna sahip idari birimdir.

Organizational Unit (OU), GPO uygulamak ve idari yetkiyi delege etmek için kullanılan konteyner yapılarıdır — güvenlik sınırı değildir; bir OU'ya **GenericAll** verilmesi, o OU altındaki tüm objeler üzerinde tam kontrol anlamına gelir.

Site, fiziksel/ağ topolojisini (IP subnet) temsil eder ve replikasyon zamanlamasını, kimlik doğrulama sunucu seçimini (DC locator) etkiler.

Schema, forest genelinde geçerli obje sınıfı ve özellik tanımlarının bulunduğu, değiştirilmesi Schema Admins yetkisi gerektiren kritik bir yapıdır — kötü niyetli bir schema değişikliği (örn. **msDS-AllowedToActOnBehalfOfOtherIdentity** gibi bir özelliğin manipülasyonu) tüm forest'i etkiler.

Teknik Arka Plan

AD Objeleri ve Güvenlik Özellikleri

Her AD objesi bir `objectSid` (güvenlik tanımlayıcı) ve bir `nTSecurityDescriptor` (DACL/SACL barındıran güvenlik tanımlayıcısı) taşır. `nTSecurityDescriptor`, Bölüm 5'te işlenecek ACL kötüye kullanımının temelidir – her obje üzerinde kimin ne yapabileceğini bu öznitelik belirler.

Kritik öznitelikler: - `userAccountControl` – hesabın devre dışı/kilitli/"password never expires" gibi bayraklarını taşır (örn. `0x10000` = `DONT_EXPIRE_PASSWD`). - `adminCount` – 1 değeri, hesabın bir zamanlar korumalı bir gruba (Domain Admins vb.) üye olduğunu ve `AdminSDHolder` süreciyle "kilitlendiğini" gösterir; bu bayrak temizlenmeden ACL miras zinciri kırık kalır (bkz. Bölüm 5). - `servicePrincipalName` (SPN) – bir hesabın Kerberoasting'e (Bölüm 4) açık olup olmadığını belirler. - `msDS-AllowedToDelegateTo`, `msDS-AllowedToActOnBehalfOfOtherIdentity` – delegasyon zincirlerini tanımlar (Bölüm 7).

Multi-Master Replikasyon

AD, tek bir "master" DC olmadan çalışan multi-master bir dizin servsidir. Her DC'de yapılan değişiklik, o DC'ye özel artan bir **USN (Update Sequence Number)** ile damgalanır. Diğer DC'ler, replikasyon ortağının en son bildiği USN'den sonraki değişiklikleri çeker (pull-based, RPC üzerinden). Çakışan değişikliklerde **yüksek USN + yüksek originating DC GUID** kuralı ve öznitelik seviyesinde **zaman damgası (stamp)** çakışma çözümü için kullanılır.

Silinen objeler hemen kaldırılmaz; **tombstone** durumuna (varsayılan 180 gün, `msDS-DeletedObjectLifetime`) geçer ve bu süre boyunca "AD Recycle Bin" özelliği açıksa geri getirilebilir. Bu, hem felaket kurtarma (Bölüm 13) hem de adli analiz açısından önemlidir – silinen bir ayrıcalıklı hesabın ne zaman ve kim tarafından silindiği tombstone/metadata üzerinden izlenebilir.

FSMO Roller

AD'de 5 tekil (single-master) rol vardır; bunlardan güvenlik açısından en kritik olanları:

Rol	Kapsam	Güvenlik Etkisi
Schema Master	Forest	Schema'yı değiştirebilen tek DC – ele geçirilirse forest çapında obje sınıfı/öznitelik manipülasyonu mümkün
Domain Naming Master	Forest	Domain ekleme/çıkarma – trust manipülasyonu ile ilişkili
PDC Emulator	Domain	Parola değişikliklerinin öncelikli replikasyon noktası, zaman senkronizasyonu, kilitlenme bilgisi – ele geçirilirse parola/kilitlenme durumu manipüle edilebilir
RID Master	Domain	RID havuzu dağıtımı – tükenmesi/manipülasyonu yeni obje oluşturmayı durdurabilir
Infrastructure Master	Domain	Cross-domain grup üyeliği referanslarını günceller

Protokol Katmanı Özeti

AD üç protokol üzerine kuruludur: **LDAP** (389/636) obje sorgulama ve değişikliği için, **Kerberos** (88) kimlik doğrulama için, **DNS** (53) servis konumlandırma (`_ldap._tcp`, `_kerberos._tcp` SRV kayıtları) için. Bu

üçünden herhangi birinin güvenliği zayıfsa (örn. LDAP signing kapalı, DNS'te dinamik güncelleme kısıtlanmamış), diğer ikisi ne kadar sağlam olursa olsun ortam saldırıya açıktır — bu yüzden Bölüm 12'de bu üç protokolün izlenmesi ayrı ayrı ele alınacaktır.

Riskler ve Tehditler

Saha Gerçekleri

Gerçek ortamlarda AD genellikle 10-20 yıllık bir birikimin üzerine kuruludur: OU yapısı organik büyümüş, eski migrasyonlardan kalma SID history girdileri temizlenmemiş, "geçici" olarak Domain Admins'e eklenip unutulmuş hesaplar mevcuttur. Bu "AD arkeolojisi", saldırı yüzeyinin asıl kaynağıdır — yeni bir zafiyetten çok, yıllar içinde birikmiş yanlış yapılandırmalar istismar edilir.

Güvenlik Riskleri

- Herhangi bir authenticated kullanıcının varsayılan olarak tüm AD şemasını ve çoğu objeyi LDAP üzerinden okuyabilmesi (read-only recon yüzeyi).
- OU'ların yanlışlıkla güvenlik sınırı sanılması ve hassas objelerin "sadece" OU delegasyonu ile korunmaya çalışılması.
- `adminCount=1` temizlenmemiş, artık ayrıcalıklı olmayan hesapların miras kırık ACL ile korumasız kalması.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Bu Bölümle İlişkisi
Account Discovery: Domain Account	T1087.002	LDAP üzerinden obje/öznitelik enumerasyonu
Permission Groups Discovery: Domain Groups	T1069.002	Grup üyeliği ve <code>adminCount</code> keşfi
Domain Trust Discovery	T1482	Forest/domain trust haritalama (bkz. Bölüm 9)

Savunma Yöntemleri

- LDAP anonim bind'i kapatın** — `dsHeuristics` üzerinden anonim erişimi devre dışı bırakın; varsayılan olarak kapalıdır ama eski migrasyonlarda açık kalabilir.
- `adminCount` temizliği** — artık ayrıcalıklı olmayan hesaplarda `adminCount` bayrağını sıfırlayın ve ACL mirasını yeniden etkinleştirin (bkz. Bölüm 5, AdminSDHolder detayı).
- OU yapısını Tier sınırlarıyla hizalayın** — OU'yu idari kolaylık için değil, Tier 0/1/2 ayrımını yansıtacak şekilde tasarlayın (bkz. Bölüm 3).
- Şema değişikliklerini değişim yönetimine bağlayın** — Schema Admins grubunu boş tutun, sadece ihtiyaç anında geçici olarak doldurun (JIT — bkz. Bölüm 10).
- Tombstone/Recycle Bin'i açık tutun ve süresini genişletin** — adli analiz ve kazara silme kurtarma için `Enable-ADOptionalFeature 'Recycle Bin Feature'`.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
Şema değişikliği onayı	R	C	I
OU/Tier yapısı tasarımı	R	A	I
adminCount denetimi	R	A	I

(R: Responsible, A: Accountable, C: Consulted, I: Informed)

Standart Eşleştirmesi

- **CIS Microsoft Active Directory Benchmark** – Bölüm 1 (Account Policies), Bölüm 2 (temel obje/şema kontrolleri).
- **NIST SP 800-53** – AC-2 (Account Management), CM-6 (Configuration Settings).

Gerçek Dünya Senaryosu: Unutulmuş Migrasyon Artığı

Bir kurumda 2012'de yapılan domain migrasyonundan kalma bir hizmet hesabı, SID history'de eski Domain Admins SID'ini taşımaya devam ediyordu. Hesabın kendisi hiçbir zaman doğrudan Domain Admins'e eklenmemişti, bu yüzde yıllık erişim gözden geçirmelerinde hiç görünmedi. Bir pentest ekibi, `Get-ADUser -Filter * -Properties SIDHistory` ile bu hesabı tespit etti ve hesabın zayıf parolasını kırarak fiilen Domain Admin yetkisiyle oturum açtı. **Ders:** Grup üyeliği denetimleri SID history'yi de kapsamalıdır; migrasyon artıkları düzenli olarak temizlenmelidir.

Kontrol Listesi

- ☐ LDAP anonim bind kapalı mı? (`dSHeuristics` kontrolü)
- ☐ `adminCount=1` olup gerçekte ayrıcalıklı olmayan hesap var mı?
- ☐ SID history'de eski/yabancı domain SID'i taşıyan hesap var mı?
- ☐ AD Recycle Bin etkin mi?
- ☐ Schema Admins / Enterprise Admins grupları boş mu (sadece JIT kullanım)?
- ☐ OU yapısı Tier sınırlarını yansıtıyor mu?

Bölüm Özeti

AD'nin forest/domain/OU hiyerarşisi, replikasyon mekanizması ve temel protokol katmanı, sonraki tüm saldırı ve savunma tartışmalarının zeminidir. En kritik çıkarım: **forest gerçek güvenlik sınırındır, domain ve OU değildir** — bu ilke Tier Modeli'nin (Bölüm 3) neden var olduğunu açıklar.

Sahada Dikkat Edilecek Noktalar

- Yıllar içinde biriken "geçici" yetkilendirmeleri düzenli tarayın.
- Yeni bir AD ortamı kurarken OU tasarımını en baştan Tier ayırımına göre planlayın — sonradan yeniden yapılandırmak çok maliyetlidir.

Ek Okuma

- Microsoft Learn: "Active Directory Domain Services Overview"
- Sean Metcalf, ADSecurity.org — "AD Recon" serisi

Kaynakça

1. Microsoft Learn, *Active Directory Domain Services*, learn.microsoft.com
2. Microsoft Learn, *How Active Directory Replication Topology Works*
3. MITRE ATT&CK, *Enterprise Matrix*, attack.mitre.org

Bölüm 2 — Tehdit Modeli & Saldırı Yüzeyi

Giriş

AD'yi savunmak için önce nasıl hedef alındığını anlamak gerekir. Bu bölüm, güncel tehdit aktörlerinin AD'ye yaklaşımını, tipik saldırı zincirini ve bu zincirin hangi bölümlerde detaylandırılacağını haritalar. Bu bölüm, kitabın geri kalanı için bir **yol haritası** işlevi görür.

Öğrenme Hedefleri

- Fidye yazılımı operasyonlarının AD'yi neden ve nasıl hedeflediğini açıklayabilmek.
- Tipik bir "breach to Domain Admin" saldırı zincirinin aşamalarını sıralayabilmek.
- Saldırı yüzeyini varlık bazında (kimlik, protokol, yapılandırma, insan) sınıflandırabilmek.

Temel Kavramlar

Saldırı yüzeyi, bir saldırganın AD'yi etkilemek için kullanabileceği tüm giriş noktalarının toplamıdır: açık portlar, yanlış yapılandırılmış izinler, zayıf parolalar, aşırı yetkilendirilmiş hesaplar, güvenilmeyen trust ilişkileri.

Saldırı zinciri (kill chain), başlangıç erişiminden nihai hedefe (genellikle Domain/Enterprise Admin, sonrasında ransomware dağıtımı veya veri sızdırma) kadar olan aşamalar dizisidir. AD bağlamında bu zincir tipik olarak şu şekilde işler: **İlk erişim** → **Yerel keşif** → **AD enumerasyonu** → **Ayrıcalık yükseltme** → **Yanal hareket** → **Domain Admin** → **Persistence (Golden Ticket vb.)** → **Etki (ransomware/exfiltration)**.

Varsayılan güven (implicit trust), AD'nin tasarım felsefesinin bir parçasıdır — her authenticated kullanıcı dizin genelinde geniş okuma erişimine sahiptir. Bu tasarım kararı, modern saldırı araçlarının (BloodHound, PowerView) neden bu kadar etkili olduğunun temel nedenidir: saldırganın ayrıcalık yükseltmek için ihtiyaç duyduğu bilginin çoğu zaten normal bir kullanıcı tarafından erişilebilir durumdadır.

Teknik Arka Plan

Tipik Saldırı Zinciri — Aşama Aşama

1. **İlk Erişim**: Phishing (kimlik bilgisi hasadı), açık RDP/VPN, tedarik zinciri, güvenlik açığı istismarı (VPN cihazları, Exchange, web uygulamaları).
2. **Yerel Keşif**: Ele geçirilen host üzerinde önbelleğe alınmış kimlik bilgileri, tarayıcıda kayıtlı parolalar, LSASS belleği.
3. **AD Enumerasyonu**: LDAP/SAMR üzerinden kullanıcı, grup, ACL, GPO, trust keşfi — genellikle BloodHound ile grafik haline getirilir (bkz. Bölüm 5).
4. **Ayrıcalık Yükseltme**: Kerberoasting (Bölüm 4), ACL kötüye kullanımı (Bölüm 5), ADCS istismarı (Bölüm 6), delegasyon zincirleri (Bölüm 7), yanlış yapılandırılmış GPO (Bölüm 8).

5. **Yanal Hareket:** Pass-the-Hash, Pass-the-Ticket, WMI/PsExec/WinRM ile host'lar arası geçiş — her host'ta yeni kimlik bilgisi hasadı ile döngü tekrarlanır.
6. **Domain Admin / Tier 0 İhlali:** Genellikle bir DC'ye yerel admin erişimi veya DCSync hakları elde edilmesiyle sonuçlanır.
7. **Persistence:** Golden Ticket, Skeleton Key, AdminSDHolder manipülasyonu, DSRM hesabı — DC'ye erişim kaybedilse bile geri dönüş yolu bırakılır (bkz. Bölüm 4 ve 13).
8. **Etki:** Ransomware dağıtımı (genellikle GPO üzerinden domain genelinde), çift gasp için veri sızdırma, iş sürekliliğinin kesintiye uğratılması.

Saldırı Yüzeyinin Dört Katmanı

Katman	Örnekler	İlgili Bölüm
Kimlik	Zayıf parola, kerberoastable SPN, AS-REP roastable hesap	4, 10
Yetkilendirme	Aşırı geniş ACL, delegasyon, grup üyeliği	5, 7
Yapılandırma	ADCS şablonları, GPO, trust ayarları, protokol (NTLM/LLMNR)	6, 8, 9
İnsan/Süreç	Yama yönetimi, değişiklik yönetimi, izleme kültürü	12, 14

Riskler ve Tehditler

Saha Gerçekleri

Fidye yazılımı operasyonlarının büyük çoğunluğunda saldırganlar "sıfır gün" kullanmaz — bilinen, yıllardır dokümente edilmiş yanlış yapılandırmaları (Kerberoasting, aşırı geniş ACL, korunmasız ADCS şablonları) istismar ederler. Bu, savunmanın önceliğinin **yeni tehdit istihbaratı takibi değil, temel hijyen** olduğunu gösterir.

Güvenlik Riskleri

- Saldırı zincirinin her aşaması bağımsız değil, birbirine zincirlenmiş risklerdir — tek bir aşamayı kapatmak (örn. sadece phishing eğitimi) zinciri kırmaz.
- Çoğu ortamda saldırgan, ilk erişimden Domain Admin'e ortalama birkaç saat içinde ulaşır ("breakout time") — tespit penceresi çok dardır.

MITRE ATT&CK Eşleştirmesi (Genel Zincir)

Aşama	Taktik	Örnek Teknik
İlk Erişim	Initial Access (TA0001)	Phishing (T1566)
Keşif	Discovery (TA0007)	Account Discovery (T1087)
Ayrıcalık Yükseltme	Privilege Escalation (TA0004)	Steal or Forge Kerberos Tickets (T1558)

Aşama	Taktik	Örnek Teknik
Yanal Hareket	Lateral Movement (TA0008)	Pass the Hash (T1550.002)
Kalıcılık	Persistence (TA0003)	Golden Ticket (T1558.001)
Etki	Impact (TA0040)	Data Encrypted for Impact (T1486)

Savunma Yöntemleri

1. **Zinciri her aşamada kırmayı hedefleyin** — tek bir kontrole güvenmeyin; savunma derinliği (defense in depth) ilkesini uygulayın.
2. **Breakout time'ı büyütün, tespit süresini küçültün** — MFA, ayrıcalık ayırımı ve hijyen breakout time'ı uzatır; SIEM/Sigma kuralları (Bölüm 12) tespit süresini kısaltır.
3. **Temel hijyene öncelik verin** — yeni araç almadan önce Kerberoasting, ACL, ADCS gibi bilinen yanlış yapılandırmaları kapatın.
4. **Purple team egzersizleri planlayın** — saldırı zincirini kendi ortamınızda kontrollü şekilde simüle edin.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	SOC	AD/Altyapı	CISO
Saldırı zinciri tatbikatı	R	C	A
Breakout time ölçümü	R	I	A
Temel hijyen denetimi	C	R	A

Standart Eşleştirmesi

- **NIST Cybersecurity Framework** — Identify/Protect/Detect fonksiyonları.
- **MITRE ATT&CK** — saldırı zinciri haritalama için referans çerçeve.

Gerçek Dünya Senaryosu: Phishing'den Ransomware'e 6 Saat

Bir orta ölçekli kurumda, bir çalışan phishing e-postasındaki makrolu belgeyi açtı. Saldırgan, host'ta ön belleğe alınmış bir hizmet hesabı kimlik bilgisini buldu; bu hesap kerberoastable bir SPN'e sahipti ve zayıf bir parola kullanıyordu. Kerberoasting ile parola kırıldı, hesabın bir dosya sunucusunda yerel admin olduğu görüldü, oradan LSASS dump ile bir Domain Admin oturumu yakalandı. Toplam süre: 6 saat. SIEM, Kerberoasting'e (aşırı sayıda TGS talebi) ait hiçbir uyarı üretmedi çünkü Event ID 4769 izlenmiyordu. **Ders:** Zincirin her aşaması ayrı ayrı önlenebilirdi (SPN hijyeni, LAPS, EDR, Kerberoasting tespiti); hiçbir uygulanmamıştı.

Kontrol Listesi

- ☐ Kurumunuzun "breakout time" tahmini var mı (tabletop/purple team ile ölçüldü mü)?
- ☐ Saldırı zincirinin her aşaması için en az bir tespit kontrolü var mı?
- ☐ Son 12 ayda bir AD-odaklı purple team egzersizi yapıldı mı?
- ☐ Kerberoasting, ACL kötüye kullanımı gibi bilinen yanlış yapılandırmalar için temel taramalar düzenli mi?

Bölüm Özeti

AD'ye yönelik saldırılar genellikle sıfır gün değil, bilinen yanlış yapılandırmaların zincirlenmesiyle gerçekleşir. Savunma stratejisi bu nedenle **zinciri kırmaya** odaklanmalı, tek bir kontrole güvenmemelidir. Sonraki bölümler bu zincirin her halkasını ayrı ayrı derinlemesine ele alacaktır.

Sahada Dikkat Edilecek Noktalar

- "Bize kimse saldırmaz" varsayımı yerine "ne zaman" sorusuyla planlama yapın.
- Tespit kontrollerini saldırı zincirinin erken aşamalarına (keşif, ilk ayrıcalık yükseltme) yoğunlaştırın – geç aşamada (Domain Admin sonrası) tespit çoğu zaman çok geçtir.

Ek Okuma

- MITRE ATT&CK Enterprise Matrix, attack.mitre.org
- Mandiant M-Trends yıllık raporları (breakout time istatistikleri)

Kaynakça

1. MITRE ATT&CK, *Enterprise Matrix*

2. Mandiant, *M-Trends Annual Threat Report*

3. Microsoft Security Blog, *Ransomware as a Service* araştırma serisi

Bölüm 3 — Tier Modeli 0/1/2 (Çekirdek Bölüm)

Giriş

Bu bölüm rehberin merkezidir. Diğer tüm bölümler — Kerberos'tan ADCS'e, GPO'dan izlemeye kadar — burada tanımlanan Tier Modeli'ne referans verir. Tier Modeli, "hangi zafiyeti kapatayım" sorusundan "hangi ayrıcalık sınırını asla ihlal ettirmeyeceğim" sorusuna geçişi temsil eder. Bu geçiş, AD güvenliğinde olgunluğun en belirleyici işaretidir.

Öğrenme Hedefleri

- Tier 0/1/2 modelinin tanımını ve her katmana hangi varlıkların girdiğini doğru sınıflandırabilmek.
- "Credential exposure" ilkesini ve neden Tier ihlallerinin çoğunun buradan kaynaklandığını açıklayabilmek.
- ESAE/Red Forest modelinden günümüzün basitleştirilmiş Tiering yaklaşımına geçişin nedenini bilmek.
- PAW, Authentication Policy Silos, temiz kaynak ilkesi (clean source principle) gibi uygulama mekanizmalarını kullanabilmek.
- Kendi ortamınız için bir Tier uygulama yol haritası çıkarabilmek.

Temel Kavramlar

Tier Modeli, Microsoft'un 2014'te "Pass-the-Hash" saldırılarına karşı yayınladığı, ayrıcalıklı erişimi üç katmana ayıran referans mimaridir:

- **Tier 0** — AD ormanının, domain'lerinin ve DC'lerinin tam kontrolüne doğrudan veya dolaylı olarak sahip her şey: DC'ler, AD CS sunucuları (özellikle CA), Domain Admins/Enterprise Admins üyeleri, AD'yi yöneten PAM/PIM çözümleri, Tier 0 sistemlerini yöneten yedekleme yazılımları, Tier 0'a erişebilen yönetim araçları (bazı SCCM/Configuration Manager kurulumları dahil).
- **Tier 1** — Kurumsal sunucular ve uygulamalar: üye sunucular, veritabanı sunucuları, uygulama sunucuları, orta ölçekli hizmet hesapları. Tier 1 yöneticisi bu sunucularda tam yetkiye sahiptir ama Tier 0'a erişemez.
- **Tier 2** — Kullanıcı iş istasyonları ve son kullanıcı destek yetkisi: help desk, iş istasyonu yöneticileri. Tier 2 yöneticisi iş istasyonlarında yetkilidir ama sunuculara veya DC'lere erişemez.

Temel ilke — Credential Exposure Prevention: Bir üst tier'ın kimlik bilgisi, hiçbir zaman bir alt tier'daki bir sistemde önbelleğe alınmamalıdır. Bir Domain Admin, bir Tier 2 iş istasyonunda oturum açtığı anda, o istasyondaki her yerel admin (veya EDR/RMM aracı, veya kötü amaçlı yazılım) o kimlik bilgisini LSASS belleğinden çalabilir. **Tier ihlallerinin neredeyse tamamı bu tek kuralın çiğnenmesinden kaynaklanır.**

Temiz Kaynak İlkesi (Clean Source Principle): Bir varlığın güvenlik düzeyi, onu yöneten/kontrol eden tüm varlıkların güvenlik düzeyinden yüksek olamaz. Yani bir Tier 0 hesabı, güvenli Tier 0 seviyesinde olmayan bir cihazdan (örn. günlük kullanım laptopu) asla kullanılmamalıdır — bu PAW kavramının (aşağıda) temelidir.

Teknik Arka Plan

ESAE / "Red Forest"ten Basitleştirilmiş Tiering'e

Microsoft, 2015-2019 arası dönemde **ESAE (Enhanced Security Admin Environment)** olarak bilinen, ayrı bir "yönetim ormanı" (Red Forest) kurulmasını öneren bir mimari yayınlamıştı. Bu model, Tier 0 yönetimini tamamen ayrı bir forest'e taşıyarak izole ediyordu. 2019'da Microsoft bu yaklaşımı **resmi olarak deprecate etti** ve yerine daha basit, bulut kimlik entegrasyonuna (Entra ID/PIM) uyumlu, tek forest içinde **rol bazlı Tiering ve Privileged Access Strategy** yaklaşımını önerdi. Bunun nedeni: Red Forest'in operasyonel karmaşıklığı çok yüksekti ve çoğu kurum bunu doğru işletemiyordu – yarım uygulanmış bir Red Forest, hiç uygulanmamış olmaktan daha az güvenli olabiliyordu.

Bu rehberde önerilen yaklaşım: Küçük/orta ölçekli kurumlar için basitleştirilmiş tek-forest Tiering + PAW + Authentication Policy Silos; çok büyük/regüle ortamlarda (finans, kritik altyapı) hâlâ ayrı bir yönetim forest'i değerlendirilebilir, ancak bu istisnadır, varsayılan değil.

Tier 0 Varlık Envanteri — Sıkça Kaçırılanlar

Tier 0'ı sadece "DC'ler ve Domain Admins" olarak düşünmek en yaygın hatadır. Aşağıdakiler de Tier 0'dır çünkü DC'leri kontrol etme yetkisine sahiptirler:

- **AD CS Sertifika Otoriteleri** — bir CA'yı ele geçiren, herhangi bir kullanıcı adına kimlik doğrulama sertifikası üretebilir (bkz. Bölüm 6).
- **GPO'yu DC'lere veya Domain Controllers OU'suna uygulayan herkes** — GPO düzenleme yetkisi fiilen kod çalıştırma yetkisidir (bkz. Bölüm 8).
- **Yedekleme yazılımı ajanları DC'ler üzerinde çalışıyorsa** — yedekleme sunucusunun kendisi Tier 0'dır.
- **SCCM/Configuration Manager, DC'lere yazılım/betik dağıtıyorsa** — SCCM site sunucusu ve onu yönetenler Tier 0'dır.
- **PAM/PIM çözümünün kendisi** — Tier 0 kimlik bilgilerini saklayan/rotasyon eden sistem, tanım gereği Tier 0'dır.
- **Sanallaştırma katmanı** — DC'ler sanal makine ise, hypervisor yöneticileri (vCenter/Hyper-V host admin) fiilen DC'nin diskine erişebilir; bu da onları Tier 0 yapar.

Uygulama Mekanizmaları

1. **Ayrı Yönetici Hesapları** — her tier için farklı, birbirine bağlı olmayan hesaplar (`adm0-` , `adm1-` , `adm2-` gibi önekler). Bir kişi birden fazla tier'da görev yapıyorsa, her tier için ayrı hesaba sahip olmalıdır.
2. **PAW (Privileged Access Workstation)** — Tier 0 yönetimi yalnızca sertleştirilmiş, internet erişimi olmayan, sadece yönetim amaçlı kullanılan fiziksel/sanal iş istasyonlarından yapılmalıdır. PAW, günlük e-posta/web tarama gibi işler için **asla** kullanılmaz.
3. **Authentication Policy Silos** (Windows Server 2012 R2+) — belirli hesapların yalnızca belirli host sınıflarında oturum açabilmesini AD seviyesinde zorunlu kılan mekanizma. Örnek PowerShell:

```
# Tier 0 için authentication policy silosu oluştur
New-ADAuthenticationPolicySilo -Name "Tier0-Silo" `
  -UserAuthenticationPolicy "Tier0-AuthPolicy" `
```



```
-ComputerAuthenticationPolicy "Tier0-Computer-AuthPolicy" `
-Enforce
```

```
# Kullanıcı ve bilgisayarları silo'ya ata
```

```
Set-ADAccountAuthenticationPolicySilo -Identity "adm0-jdoe" -AuthenticationPolicySilo "Tier0-Silo"
```

```
Set-ADAccountAuthenticationPolicySilo -Identity "DC01$" -AuthenticationPolicySilo "Tier0-Silo"
```

1. **GPO ile Logon Rights Kısıtlaması** – "Deny log on locally/through Remote Desktop Services" ile Tier 0 hesaplarının Tier 1/2 sistemlerde, Tier 1 hesaplarının Tier 2 sistemlerde oturum açması GPO seviyesinde engellenir. Bu, Authentication Policy Silos'un olmadığı (veya henüz uygulanmadığı) ortamlarda asgari savunma katmanıdır.
2. **LAPS/Windows LAPS** – Tier 1/2 sistemlerde yerel admin parolalarının tekilleştirilmesi; bir sistemin ele geçirilmesinin diğerlerine "pass the hash" ile yayılmasını engeller (bkz. Bölüm 11).

Riskler ve Tehditler

Saha Gerçekleri

En sık görülen tier ihlali şudur: bir AD yöneticisi, günlük kullandığı laptopundan (Tier 2 güven seviyesinde) uzak masaüstü ile bir DC'ye (Tier 0) bağlanır. Bu tek işlem, laptopun güvenlik seviyesini fiilen DC seviyesine düşürür – çünkü laptop artık Tier 0 kimlik bilgisi barındırıyor. Laptop kimlik avına veya bir güvenlik açığına maruz kalırsa, saldırgan doğrudan Domain Admin yetkisi elde eder.

Güvenlik Riskleri

- **Tier 0 sprawl**: Zamanla, "geçici" olarak eklenen araçlar (izleme ajanı, yedekleme ajanı, RMM) fark edilmeden Tier 0 saldırı yüzeyini genişletir.
- **Tek hesaplara çoklu tier yönetimi**: Aynı hesabın hem Tier 0 hem Tier 1 sistemlerde kullanılması, tier ayrımını fiilen ortadan kaldırır.
- **PAW'ın "bazen" kullanılması**: PAW politikası varken bile, acil durumlarda "bu sefer laptoptan bağlanayım" istisnası tier modelini anlamsız kılar – istisna kültürü en büyük düşmandır.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Bu Bölümle İlişkisi
OS Credential Dumping: LSASS Memory	T1003.001	Tier ihlali sonucu üst tier kimlik bilgisinin alt tier sistemde çalınması
Valid Accounts: Domain Accounts	T1078.002	Tier sınırını aşan hesap kullanımı
Remote Services: Remote Desktop Protocol	T1021.001	Tier 2'den Tier 0'a RDP ile doğrudan erişim

Savunma Yöntemleri

1. **Tier 0 envanterini eksiksiz çıkarın** – sadece DC'ler değil, yukarıda listelenen "sıkça kaçırılan" tüm varlıkları dahil edin. Bu envanter, AD Guard gibi bir denetim aracının **tier_analyzer** modülünün çıktısıyla çapraz doğrulanmalıdır.
2. **PAW'ı zorunlu kılın, istisna vermeyin** – teknik kontrolle (Authentication Policy Silo + GPO logon rights) istisnaları imkansız hale getirin, sadece politika ile değil.
3. **Authentication Policy Silos'u aşamalı uygulayın** – önce Tier 0 için (en yüksek risk azaltımı, en düşük operasyonel sürtünme), sonra Tier 1.
4. **Her tier için ayrı, birbirine bağlı olmayan kimlik bilgisi kullanın** – parola paylaşımı veya "aynı parolanın farklı hesaplarda kullanımı" tier ayrımını boşa çıkarır.
5. **Düzenli tier ihlali taraması yapın** – hangi Tier 0 hesabının hangi host'larda oturum açtığını Event ID 4624/4625 (logon type ile birlikte) üzerinden düzenli analiz edin (bkz. Bölüm 12).

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO	Uygulama Sahipleri
Tier 0 envanteri çıkarma	R	A	I	C
Authentication Policy Silo uygulama	R	C	A	I
PAW dağıtımı	R	C	A	I
Tier ihlali izleme	C	R	A	I

Standart Eşleştirmesi

- **Microsoft Privileged Access Strategy** – resmi referans mimari (ESAE'nin yerini alan güncel model).
- **CIS Controls v8** – Control 6 (Access Control Management), Control 5 (Account Management).
- **NIST SP 800-53** – AC-6 (Least Privilege), AC-6(5) (Privileged Accounts).

Gerçek Dünya Senaryosu: "Sadece Bu Seferlik" RDP

Bir kurumda AD yöneticisi, bir DC'de acil bir GPO değişikliği yapması gerektiğinde, PAW'ı yanında olmadığı için günlük laptopundan RDP ile bağlandı. Laptop, üç ay önce bir tedarik zinciri saldırısıyla bulaşmış, sessizce bekleyen bir implant barındırıyordu. RDP oturumu sırasında implant, LSASS belleğinden Domain Admin kimlik bilgisini çaldı ve saldırgan 48 saat içinde tüm ortamı fidye yazılımıyla şifreledi. Adli analiz, olayın kök nedeninin "bir zafiyet" değil, **tek bir tier ihlali** olduğunu gösterdi. **Ders:** PAW politikasının teknik olarak zorunlu kılınmaması (sadece "politika" olarak var olması), politikayı işe yaramaz hale getirir.

Kontrol Listesi

- ☐ Tier 0 varlık envanteri eksiksiz mi (CA, PAM, yedekleme, SCCM, hypervisor dahil)?
- ☐ Her tier için ayrı, birbirine bağlı olmayan yönetici hesapları var mı?
- ☐ PAW zorunlu mu ve teknik kontrole (Authentication Policy Silo/GPO) uygulanıyor mu?
- ☐ Authentication Policy Silos Tier 0 için etkin mi?
- ☐ GPO "Deny log on" kısıtlamaları tier sınırlarını yansıtıyor mu?
- ☐ Tier ihlali (üst tier hesabın alt tier sistemde oturum açması) için düzenli log analizi yapılıyor mu?
- ☐ Yeni bir sistem/araç eklendiğinde, hangi tier'a ait olduğu değerlendiriliyor mu (değişiklik yönetimi süreci)?

Bölüm Özeti

Tier Modeli, AD güvenliğinin tek bir zafiyeti kapatmaktan çok, **ayrıcalık sınırlarının asla ihlal edilmemesini** garanti altına almakla ilgili olduğunu gösterir. Credential exposure prevention ilkesi ve temiz kaynak ilkesi, modelin iki temel direğidir. ESAE/Red Forest'in karmaşıklığından kaçının; basitleştirilmiş, teknik kontrollerle zorunlu kılınan bir Tiering yaklaşımı, kağıt üzerinde mükemmel ama uygulanmayan bir mimariden çok daha güvenlidir.

Sahada Dikkat Edilecek Noktalar

- "İstisna" kelimesini duyduğunuz anda tier modelinin çığnendiğini varsayın.
- Yeni bir araç/ajan kurulumu her zaman "bu hangi tier'a erişiyor" sorusuyla değerlendirilmeli.
- PAW'ın fiziksel olarak ayrı olması operasyonel sürtünme yaratır – bu sürtünme özelliktir, hata değildir.

Ek Okuma

- Microsoft Learn: "Privileged Access Strategy"
- Microsoft Learn: "Securing Privileged Access – Enterprise Access Model"
- Microsoft Learn: "Authentication Policies and Authentication Policy Silos"

Kaynakça

1. Microsoft Learn, *Privileged Access Strategy*, learn.microsoft.com
2. Microsoft Learn, *Enterprise Access Model*
3. Microsoft Learn, *Authentication Policies and Silos*
4. Microsoft, *Securing Privileged Access Reference Material* (ESAE deprecation notice, 2019)

Bölüm 4 — Kerberos Saldırıları & Savunma

Giriş

Kerberos, AD'nin kimlik doğrulama protokolüdür ve aynı zamanda en çok istismar edilen katmanlardan biridir. Bu bölüm, Kerberoasting'den Golden Ticket'a kadar bilet tabanlı saldırıları ve bunlara karşı somut savunma kontrollerini ele alır. Bu bölümdeki tüm saldırılar, KRBTGT hesabının (Bölüm 13'te detaylandırılan) merkezi rolü etrafında döner.

Öğrenme Hedefleri

- Kerberos kimlik doğrulama akışını (AS-REQ/AS-REP, TGS-REQ/TGS-REP) adım adım açıklayabilmek.
- Kerberoasting ve AS-REP Roasting'in nasıl çalıştığını ve neden mümkün olduğunu bilmek.
- Golden/Silver/Diamond/Sapphire ticket kavramlarını ve her birinin gerektirdiği ön koşulu ayırt edebilmek.
- KRBTGT hijyeni ve bilet tabanlı saldırılara karşı tespit/savunma kontrollerini uygulayabilmek.

Temel Kavramlar

Kerberos akışı kısaca: istemci, KDC'ye (Domain Controller) kimliğini kanıtlayarak bir **TGT (Ticket Granting Ticket)** alır (AS-REQ/AS-REP). TGT, **KRBTGT hesabının parola hash'i** ile şifrelenmiştir. İstemci, bir hizmete erişmek istediğinde TGT'sini KDC'ye sunarak o hizmete özel bir **TGS (Ticket Granting Service ticket)** alır (TGS-REQ/TGS-REP); TGS, **hedef hizmet hesabının parola hash'i** ile şifrelenmiştir.

Bu iki şifreleme noktası — TGT için KRBTGT hash'i, TGS için hizmet hesabı hash'i — Kerberos saldırılarının neredeyse tamamının temelini oluşturur: **bir hash'i ele geçiren, o hash ile şifrelenmiş herhangi bir bileti sahte olarak üretebilir.**

SPN (Service Principal Name), bir hizmetin Kerberos'ta nasıl adresleneceğini tanımlayan kayıttır. Bir kullanıcı hesabına SPN atanması (tipik olarak hizmet hesaplarında), o hesabı Kerberoasting'e açık hale getirir.

Teknik Arka Plan

Kerberoasting

Herhangi bir authenticated kullanıcı, SPN'i olan herhangi bir hesap için TGS talep edebilir — bu, tasarımın normal bir parçasıdır (bir kullanıcının bir hizmete erişmesi için gereklidir). Talep edilen TGS, hedef hesabın parola hash'i ile şifrelenmiştir ve saldırgan bu bileti **offline olarak** kırmaya çalışabilir; DC'ye tekrar bağlanmaya gerek yoktur. Hesabın parolası zayıfsa (özellikle eski, "hiç değişmemiş" hizmet hesaplarında sık görülür), hash kırılır ve hesabın açık metin parolası elde edilir.

```
# Tespit tarafında en kritik olay: Event ID 4769 (Kerberos service ticket request)
# RC4 şifreleme türü (0x17) ile normalden çok sayıda TGS talebi = Kerberoasting işareti
```

AS-REP Roasting

`Do not require Kerberos preauthentication` bayrağı (`userAccountControl` içinde `DONT_REQUIRE_PREAUTH`) açık olan hesaplar için, saldırgan hesabın parolasını bilmeden doğrudan AS-REP talep edebilir. Preauthentication olmadığı için KDC, kimliği doğrulanmamış bir talebe de AS-REP ile yanıt verir; bu yanıtın bir kısmı hesabın parola hash'i ile şifrelenmiştir ve offline kırılabilir.

Golden Ticket

KRBTGT hesabının NTLM hash'i ele geçirilirse, saldırgan **herhangi bir kullanıcı için, herhangi bir grup üyeliğiyle (Domain Admins dahil), istediği süre için** sahte bir TGT üretebilir — DC'ye hiç dokunmadan. Bu bilet, KRBTGT parolası rotasyona uğramadığı sürece (varsayılan olarak asla otomatik değişmez) geçerliliğini korur. Golden Ticket, en kalıcı ve tespiti en zor persistence tekniklerinden biridir.

Silver Ticket

Golden Ticket'ın küçük ölçekli versiyonu: saldırgan, KRBTGT yerine belirli bir **hizmet hesabının** hash'ini kullanarak, sadece o hizmet için geçerli sahte bir TGS üretir. KDC'ye hiç danışılmadığı için (TGS doğrudan hedef hizmete sunulur), DC loglarında iz bırakmaz — bu da Silver Ticket'ı Golden Ticket'tan bile daha sinsi yapar, ancak etkisi tek hizmetle sınırlıdır.

Diamond Ticket ve Sapphire Ticket

Golden Ticket'ın tespit edilme riskini azaltmak için geliştirilen tekniklerdir: **Diamond Ticket**, sıfırdan sahte bilet üretmek yerine gerçek bir TGT'yi KRBTGT hash'i ile deşifre edip alanlarını (grup üyeliği vb.) değiştirip yeniden şifreler — bu, tipik Golden Ticket tespit imzalarından (örn. varsayılan 10 yıllık geçerlilik süresi) kaçınır. **Sapphire Ticket**, benzer bir yaklaşımla PAC (Privilege Attribute Certificate) doğrulama zincirini daha sinsi şekilde manipüle eder.

DCSync

Bilet saldırısı değildir ama KRBTGT hash'ini ele geçirmenin en yaygın yoludur: bir hesabın `Replicating Directory Changes All` ve `Replicating Directory Changes` haklarına sahip olması (normalde sadece DC'lerin ve Domain Admins'in sahip olduğu haklar), o hesabın kendini bir DC gibi göstererek **DC'yi gerçek replikasyon protokolü (MS-DRSR) üzerinden taklit etmesine** ve KRBTGT dahil herhangi bir hesabın hash'ini "senkronize" etmesine izin verir. Bu haklar, ACL kötüye kullanımıyla (Bölüm 5) yanlışlıkla veya kötü niyetle bir hesaba verilebilir.

Riskler ve Tehditler

Saha Gerçekleri

Kerberoasting'e açık hesaplar neredeyse her ortamda bulunur — özellikle eski uygulamalar için oluşturulmuş, "bir daha dokunulmayan" hizmet hesaplarında. Bu hesapların parolaları genellikle kuruluş anında belirlenmiş ve hiç değişmemiştir; bazen 10+ yıllıktır.

Güvenlik Riskleri

- Kerberoasting/AS-REP Roasting tespiti, çoğu ortamda hiç yapılmaz çünkü Event ID 4769 hacmi çok yüksektir ve doğru filtrelenenmeden gürültü olarak görülür.
- KRBTGT parolası, birçok ortamda kurulumdan beri hiç rotasyona uğramamıştır.
- DCSync hakları, ACL denetimleri düzenli yapılmadığı için genellikle fark edilmeden bir üçüncü taraf entegrasyon hesabına (örn. Azure AD Connect, yedekleme yazılımı) verilmiştir — bu hesapların bu haklara **meşru olarak** ihtiyacı olabilir, ancak bu hesaplar bu nedenle fiilen Tier 0'dır.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Steal or Forge Kerberos Tickets: Kerberoasting	T1558.003	SPN sahibi hesaplardan TGS hasadı
Steal or Forge Kerberos Tickets: AS-REP Roasting	T1558.004	Preauth gerektirmeyen hesaplardan AS-REP hasadı
Steal or Forge Kerberos Tickets: Golden Ticket	T1558.001	KRBTGT hash ile sahte TGT üretimi
Steal or Forge Kerberos Tickets: Silver Ticket	T1558.002	Hizmet hesabı hash'i ile sahte TGS üretimi
OS Credential Dumping: DCSync	T1003.006	Replikasyon hakları üzerinden hash hasadı

Savunma Yöntemleri

1. Kerberoasting yüzeyini daraltın:

- SPN sahibi hesaplar için 25+ karakter, rastgele, gMSA tabanlı parolalar kullanın (bkz. Bölüm 11).
- Mümkün olan her yerde SPN'li kullanıcı hesaplarını **gMSA'ya** dönüştürün — gMSA'lar otomatik, 120 karakterlik rastgele parolalar kullanır ve Kerberoasting ile pratik olarak kırılamaz.
- AES şifrelemeyi zorunlu kılın (`msDS-SupportedEncryptionTypes`), RC4'ü devre dışı bırakın.

2. AS-REP Roasting'i kapatın:

```
# Preauth gerektirmeyen hesapları bulun
Get-ADUser -Filter 'useraccountcontrol -band 4194304' -Properties useraccountcontrol
# Bayrağı kaldırın
Set-ADAccountControl -Identity <hesap> -DoesNotRequirePreAuth $false
```

3. KRBTGT parolasını düzenli rotasyona sokun (bkz. Bölüm 13 için detaylı prosedür) — yılda en az bir kez, şüpheli bir olay sonrasında ise **iki kez arka arkaya** (KRBTGT'nin geçmiş 2 parolası da geçerli kabul edildiği için).

4. DCSync haklarını denetleyin ve kısıtlayın:

```
# DCSync hakkına sahip principal'ları bulun (dsacIs veya PowerView ile)
dsacIs "DC=corp,DC=local" | Select-String "Replicating Directory Changes"
```

Sadece DC'lerin, gerçekten gerekli olan Azure AD Connect/üçüncü taraf entegrasyon hesaplarının bu hakka sahip olduğunu doğrulayın; bu hesapları Tier 0 olarak sınıflandırın.

5. Tespit kontrollerini etkinleştirin (detaylar Bölüm 12'de):

- Event ID 4769 üzerinde RC4 (0x17) şifreleme türü + yüksek hacim = Kerberoasting işareti.
- Event ID 4768 üzerinde preauth olmadan AS-REQ = AS-REP Roasting işareti.
- Event ID 4624 logon type 3 ile birlikte anormal derecede uzun bilet ömrü = Golden Ticket işareti.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	Uygulama Sahipleri
SPN hesaplarını gMSA'ya taşıma	R	C	A
KRBTGT rotasyonu	R	A	I
DCSync hak denetimi	C	R	I

Standart Eşleştirme

- **CIS Benchmark** — Kerberos ile ilgili parola politikası ve preauth kontrolleri.
- **NIST SP 800-63B** — kimlik bilgisi gücü gereksinimleri (SPN hesap parolaları için).

Gerçek Dünya Senaryosu: 11 Yıllık Hizmet Hesabı

Bir pentest sırasında, `svc_backup` adlı bir hizmet hesabının SPN'e sahip olduğu ve parolasının 11 yıldır değişmediği tespit edildi. Kerberoasting ile alınan TGS, yaygın bir wordlist ile 40 dakikada kırıldı. Hesap, yedekleme yazılımı tarafından kullanıldığı için birçok sunucuda yerel admin yetkisine sahipti — ve bu sunuculardan biri bir DC'nin yedeğini alıyordu, dolayısıyla DC diskine erişim de mümkündü. **Ders:** SPN hesaplarının yaşı ve parola karmaşıklığı düzenli denetlenmeli; hizmet hesapları mümkün olduğunda gMSA'ya taşınmalıdır.

Kontrol Listesi

- ☐ SPN sahibi hesapların parolaları 25+ karakter mi ve gMSA'ya taşınabiliyor mu?
- ☐ `DONT_REQUIRE_PREAUTH` bayraklı hesap var mı?

- ☐ KRBGTGT parolası son 12 ay içinde rotasyona girdi mi?
- ☐ DCSync hakkına sahip principal listesi güncel ve gerekçelendirilmiş mi?
- ☐ Event ID 4769/4768/4624 üzerinde Kerberoasting/AS-REP Roasting/Golden Ticket tespiti aktif mi?
- ☐ RC4 şifreleme devre dışı, AES zorunlu mu?

Bölüm Özeti

Kerberos saldırılarının ortak paydası, bir hash'in ele geçirilmesinin o hash ile şifrelenmiş herhangi bir bileti sahteletirmeye yetmesidir. Savunmanın iki ana kolu: **hash'lerin çalınmasını zorlaştırmak** (gMSA, AES, güçlü parolalar) ve **KRBGTGT'yi düzenli rotasyona sokmak**. Bu ikisi olmadan, diğer tüm kontroller (izleme dahil) sadece tespiti hızlandırır, saldırıyı önlemez.

Sahada Dikkat Edilecek Noktalar

- "SPN'i olan her hesap potansiyel bir Kerberoasting hedefidir" varsayımıyla hareket edin.
- KRBGTGT rotasyonunu takvime bağlayın — "hatırlarsak yaparız" yaklaşımı işe yaramaz.

Ek Okuma

- Microsoft Learn: "Kerberos Authentication Overview"
- Sean Metcalf, ADSecurity.org — "Kerberoasting" ve "Golden Ticket" serileri
- SpecterOps araştırma yayınları — bilet manipülasyon teknikleri

Kaynakça

1. Microsoft Learn, *Kerberos Authentication Technical Overview*
2. MITRE ATT&CK, T1558 (Steal or Forge Kerberos Tickets) alt teknikleri
3. Microsoft Learn, *AD DS: KRBGTGT Account Password Reset Scripts*

Bölüm 5 — ACL/DACL Kötüye Kullanımı

Giriş

AD'deki her obje bir ACL (Access Control List) taşır ve bu ACL'ler, kim kimin üzerinde ne yapabilir sorusunu belirler. Yanlış yapılandırılmış ACL'ler, AD'deki en yaygın ve en az anlaşılan ayrıcalık yükseltme yoludur — çünkü bir GUI'de tek bir onay kutusu işaretlemek, fark edilmeden Domain Admin'e giden bir yol açabilir.

Öğrenme Hedefleri

- ACL/DACL yapısını ve AD'deki en kritik izin türlerini (GenericAll, WriteDAcl, WriteOwner vb.) tanımlayabilmek.
- BloodHound'un attack path mantığının ACL verisi üzerine nasıl kurulduğunu anlamak.
- AdminSDHolder/SDProp sürecinin ACL güvenliğindeki rolünü açıklayabilmek.
- ACL hijyeni için pratik denetim ve düzeltme adımlarını uygulayabilmek.

Temel Kavramlar

DACL (Discretionary Access Control List), bir obje üzerinde kimin hangi işlemi yapabileceğini tanımlayan izin girdileri (ACE — Access Control Entry) listesidir. Her ACE bir **principal** (kullanıcı/grup), bir **hak** (GenericAll, WriteProperty vb.) ve bir **kapsam** (sadece bu obje mi, alt objelere miras mı) içerir.

En kritik AD hakları:

Hak	Anlamı	Risk
GenericAll	Obje üzerinde tam kontrol	Parola sıfırlama, grup üyeliği değiştirme, her şey
GenericWrite	Çoğu özneteliği yazabilme	scriptPath , msDS-AllowedToDelegateTo gibi kritik alanları değiştirme
WriteDAcl	Objenin ACL'ini değiştirebilme	Kendine GenericAll verip zinciri sonlandırma
WriteOwner	Obje sahipliğini değiştirebilme	Sahiplik alındıktan sonra ACL'i istediğin gibi yeniden yazabilme
ForceChangePassword	Mevcut parolayı bilmeden parola değiştirme	Hesabı doğrudan ele geçirme
AllExtendedRights (DS-Replication-Get-Changes-All ile birlikte)	DCSync dahil genişletilmiş haklar	Bölüm 4'te işlenen DCSync

AdminSDHolder ve SDProp, ayrıcalıklı grupların (Domain Admins, Enterprise Admins, Schema Admins vb.) ve üyelerinin ACL'lerini korumak için AD'nin kendi kendine çalıştığı bir mekanizmadır: her 60 dakikada bir **SDProp** süreci, **AdminSDHolder** objesindeki "şablon" ACL'i, korunan gruplara ve **o an üye olan/olmuş** hesaplara kopyalar ve kalıtımı keser (**adminCount=1**). Bu mekanizma çift yönlü bir kılıçtır: hem korumayı sağlar hem de yanlış anlaşıldığında (Bölüm 1'de değinilen "eski adminCount temizliği" sorunu) uzun vadeli kafa karışıklığına yol açar.

Teknik Arka Plan

ACL Zincirleri ve BloodHound Mantiği

Gerçek dünyada tehlikeli olan tekil bir ACE değil, **ACL zincirleridir**: Kullanıcı A, Grup B üzerinde **GenericWrite** sahibidir → Grup B, bir GPO'nun uygulandığı OU üzerinde yazma yetkisine sahiptir → o GPO, Domain Admin'in login script'ini kontrol eder → zincir tamamlanır, A fiilen Domain Admin'dir. Hiçbir tekil adım "Domain Admin yetkisi" gibi görünmez; sadece zincirin tamamı haritalandığında risk ortaya çıkar. **BloodHound**, LDAP üzerinden topladığı ACL/grup üyeliği verisini bir graf veritabanına (Neo4j) yükleyerek bu zincirleri otomatik olarak bulur — bu, hem saldırganların hem savunmacıların (Purple Knight, PingCastle gibi araçlarla birlikte) kullandığı standart yöntemdir.

Sık Görülen Tehlikeli ACL Kalıpları

1. **Help desk grubuna verilen aşırı geniş OU delegasyonu** — "kullanıcı parolası sıfırlayabilsin" denilerek verilen delegasyon, sihirbaz varsayılanlarıyla genellikle **GenericAll** kapsamına kayar.
2. **Eski migrasyon/entegrasyon hesaplarına unutulmuş WriteDACL** — bir zamanlar geçici bir proje için verilmiş, asla geri alınmamış haklar.
3. **Bilgisayar objelerine kendi kendine GenericWrite** (self-membership benzeri durumlar) — RBCD (Bölüm 7) ile birleştiğinde ayrıcalık yükseltmeye dönüşebilir.
4. **Everyone / Authenticated Users / Domain Users** gibi geniş gruplara verilmiş yazma hakları — özellikle GPO veya OU seviyesinde.

AdminSDHolder Kötüye Kullanımı

Saldırgan, **AdminSDHolder** objesinin kendi ACL'ini değiştirme hakkı elde ederse, kendi kontrolündeki bir hesaba **GenericAll** ekleyebilir; bu değişiklik SDProp döngüsünde (60 dakika içinde) **tüm korumalı ayrıcalıklı gruplara ve üyelerine otomatik olarak yayılır** — bu, tek bir ACL değişikliğiyle domain genelinde kalıcı erişim sağlayan en güçlü persistence tekniklerinden biridir.

Riskler ve Tehditler

Saha Gerçekleri

Çoğu kurumda ACL denetimi hiç yapılmaz çünkü GUI üzerinden (ADUC "Delegation of Control Wizard") verilen haklar "görünmez" kalır — kimse periyodik olarak "bu OU'da kim ne yapabiliyor" sorusunu sormaz. BloodHound taramaları, neredeyse her üretim ortamında en az bir "kısa yol" (shortest path to Domain Admins) bulur.

Güvenlik Riskleri

- ACL zincirleri, tekil olarak zararsız görünen delegasyonların birleşimiyle oluşur — geleneksel "zafiyet tarama" araçları bunu yakalayamaz, graf analizi gerekir.
- `AdminSDHolder` / `SDProp` mekanizması yeterince anlaşılmadığında, hem yanlış pozitif (temizlenmemiş `adminCount`) hem yanlış negatif (kötüye kullanım fark edilmeden) sonuçlar doğurur.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Permission Groups Discovery: Domain Groups	T1069.002	ACL/grup zinciri keşfi (BloodHound)
Account Manipulation: AD Object	T1098 (ilgili alt teknikler)	ACE ekleme/değiştirme
Abuse Elevation Control Mechanism	T1548 (ilişkili)	WriteDACL/WriteOwner ile ayrıcalık yükseltme

Savunma Yöntemleri

1. **Düzenli BloodHound taraması yapın (savunma amaçlı)** — kendi ortamınızda "shortest path to Domain Admins" sorgusunu düzenli çalıştırın, yeni bulunan her yolu kapatın.
2. **Delegasyon sihirbazını GUI yerine PowerShell ile, en az yetki ilkesiyle yapın** — `dsacIs` veya `Set-Acl` ile sadece gerekli olan spesifik hakkı (örn. sadece `Reset Password` extended right) verin, `GenericAll` vermeyin.
3. **`adminCount=1` denetimini periyodik hale getirin** — artık ayrıcalıklı olmayan hesapları tespit edip ACL mirasını yeniden etkinleştirin (bkz. Bölüm 1).
4. **`AdminSDHolder` ACL'ini düzenli denetleyin** — bu objenin kendi ACL'inde beklenmeyen bir principal varsa, bu ciddi bir persistence göstergesidir.
5. **Yüksek riskli grupları (Everyone, Authenticated Users, Domain Users) ACL denetiminde özel olarak arayın** — bu gruplara verilmiş herhangi bir yazma hakkı incelemeye alınmalıdır.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
BloodHound taraması (savunma)	C	R	I
Delegasyon gözden geçirme	R	A	I

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
AdminSDHolder denetimi	C	R	A

Standart Eşleştirmesi

- **CIS Benchmark** — yetkilendirme ve delegasyon kontrolleri.
- **NIST SP 800-53** — AC-3 (Access Enforcement), AC-6 (Least Privilege).

Gerçek Dünya Senaryosu: Help Desk'ten Domain Admin'e

Bir kurumda help desk ekibine, kullanıcı parolalarını sıfırlayabilmeleri için bir OU üzerinde delegasyon verildi. Delegasyon sihirbazı kullanılırken yanlışlıkla "tam kontrol" seçildi. Bu OU'nun altında, unutulmuş bir eski proje hesabı vardı ve bu hesap, `AdminSDHolder` üzerinde dolaylı olarak yazma hakkına sahip bir gruba üyeydi. Bir pentest ekibi, help desk seviyesindeki bir hesaptan başlayarak üç adımlık bir ACL zinciriyle Domain Admin yetkisine ulaştı. **Ders:** Delegasyon sihirbazının varsayılan seçimlerini asla sorgulamadan kabul etmeyin; her delegasyon sonrası verilen fiili hakları `dsac ls` ile doğrulayın.

Kontrol Listesi

- ☐ Son 6 ay içinde BloodHound (veya eşdeğeri) ile "shortest path to Domain Admins" taraması yapıldı mı?
- ☐ Everyone/Authenticated Users/Domain Users gruplarına verilmiş yazma hakkı var mı?
- ☐ `AdminSDHolder` ACL'inde beklenmeyen principal var mı?
- ☐ Delegasyonlar sihirbaz varsayılanları yerine spesifik haklarla mı veriliyor?
- ☐ `adminCount=1` olup artık ayrıcalıklı olmayan hesaplar temizlendi mi?

Bölüm Özeti

ACL kötüye kullanımı, AD'nin en az anlaşılan ama en sık istismar edilen saldırı yüzeyidir çünkü tehlike tekil izinlerde değil, **zincirlerde** saklıdır. BloodHound gibi graf tabanlı analiz araçları, hem saldırganların hem savunmacıların bu zincirleri görmesini sağlayan standart yöntemdir — bu aracı düzenli olarak savunma amaçlı kullanmayan bir kurum, saldırganın ondan önce bu yolları bulmasına izin veriyor demektir.

Sahada Dikkat Edilecek Noktalar

- Delegasyon sihirbazının verdiği "kolaylık", genellikle gereğinden fazla yetki anlamına gelir.
- ACL denetimini bir kerelik proje değil, sürekli bir süreç olarak kurun.

Ek Okuma

- SpecterOps, "An ACE Up the Sleeve: Designing Active Directory DACL Backdoors"
- BloodHound resmi dokümantasyonu

Kaynakça

1. SpecterOps, *BloodHound Documentation*
 2. Microsoft Learn, *AdminSDHolder, Protected Groups and SDProp*
 3. MITRE ATT&CK, T1069 (Permission Groups Discovery)
-

Bölüm 6 — AD CS / ESC1-14

Giriş

Active Directory Certificate Services (AD CS), 2021'den itibaren SpecterOps'un "Certified Pre-Owned" araştırmasıyla AD güvenliğinin en kritik gündemlerinden biri haline geldi. AD CS yanlış yapılandırmaları, genellikle **tek bir zafiyetle doğrudan Domain Admin** sonucu doğurur ve bu bölümde ele alınan ESC (Escalation) senaryoları, Tier 0'ın (Bölüm 3) neden CA'yı da kapsamı gerektiğinin somut kanıtıdır.

Öğrenme Hedefleri

- AD CS'in temel bileşenlerini (CA, sertifika şablonu, enrollment) tanımlayabilmek.
- ESC1-14 senaryolarının genel mantığını ve risk seviyelerini ayırt edebilmek.
- Sertifika şablonu hijyeni için pratik denetim adımlarını uygulayabilmek.

Temel Kavramlar

Certificate Authority (CA), sertifika imzalayan güvenilir otoritedir. Kurumsal (Enterprise) CA, AD'ye entegredir ve sertifika şablonlarını (certificate templates) AD üzerinden yayımlar.

Sertifika şablonu, bir sertifikanın hangi amaçla (kimlik doğrulama, kod imzalama, e-posta vb.), kimler tarafından talep edilebileceğini ve hangi alanların talep eden tarafından belirlenebileceğini tanımlayan yapılandırmadır.

Certificate-Based Authentication, bir sertifikanın **Client Authentication** EKU'suna (Extended Key Usage) sahip olması ve **Subject Alternative Name** (SAN) alanında bir kullanıcı adı/UPN taşıması durumunda, o sertifikayla **parola gerekmeden** Kerberos kimlik doğrulaması (PKINIT) yapılabilmesidir. ESC senaryolarının çoğu, bu mekanizmanın kötüye kullanılmasına dayanır.

Teknik Arka Plan

ESC Senaryolarına Genel Bakış

SpecterOps'un orijinal araştırması ESC1-8'i tanımladı; sonraki araştırmalar (özellikle Certipy ve topluluk katkılarıyla) ESC9-14'ü ekledi. Aşağıdaki tablo özet niteliğindedir; her biri ayrı bir teknik derinliğe sahiptir:

ESC	Kısa Açıklama	Kök Neden
ESC1	Düşük ayrıcalıklı kullanıcı, SAN alanını kendisi belirleyerek herhangi bir kullanıcı (örn. Domain Admin) adına sertifika talep edebiliyor	Şablon ENROLLEE_SUPPLIES_SUBJECT + Client Auth EKU + düşük ayrıcalıklı enrollment hakkı
ESC2	Şablon "Any Purpose" EKU'suna veya EKU'suz yapılandırılmış, bu da sertifikanın kimlik doğrulama dahil her amaçla kullanılmasına izin veriyor	Aşırı geniş EKU tanımı

ESC	Kısa Açıklama	Kök Neden
ESC3	Şablon, "Certificate Request Agent" hakkı vererek bir kullanıcının başkası adına sertifika talep etmesine (enrollment agent) izin veriyor	Kötüye kullanılabilir agent şablonu
ESC4	Şablonun kendi ACL'i üzerinde düşük ayrıcalıklı bir kullanıcının yazma hakkı var – şablonu ESC1'e dönüştürebiliyor	Şablon ACL zafiyeti (Bölüm 5 ile kesişir)
ESC5	CA nesnesinin veya PKI AD objelerinin (örn. <code>pKIEnrollmentService</code>) ACL'i zayıf – CA yapılandırmasını manipüle etme	Nesne seviyesi ACL zafiyeti
ESC6	CA, <code>EDITF_ATTRIBUTESUBJECTALTNAME2</code> bayrağıyla yapılandırılmış – herhangi bir şablonda SAN enjeksiyonuna izin veriyor	CA seviyesi tehlikeli bayrak
ESC7	Kullanıcı, CA üzerinde <code>Manage CA</code> veya <code>Manage Certificates</code> hakkına sahip – sertifika onayı/iptalini manipüle edebiliyor	CA rol tabanlı erişim zafiyeti
ESC8	AD CS web enrollment (HTTP) NTLM relay'e açık – bir makine hesabı adına relay ile sertifika alınabiliyor	NTLM relay + HTTP enrollment
ESC9	<code>szOID_NTDS_CA_SECURITY_EXT</code> (yeni güvenlik uzantısı) şablon üzerinde devre dışı, zayıf eşleme (mapping) senaryolarını mümkün kılıyor	Sertifika güvenlik uzantısı eksikliği
ESC10	Zayıf sertifika-hesap eşleme modları (<code>UPN</code> alanı gibi zayıf alanlara güven) kimlik sahteciliğine izin veriyor	DC eşleme yapılandırması
ESC11	CA'nın ICPR (RPC) arayüzü NTLM relay'e açık	RPC seviyesinde relay
ESC12	CA'nın özel anahtarı, saldırganın erişebileceği bir HSM/ donanım yapılandırmasında yanlış korunuyor	Anahtar koruma zafiyeti
ESC13	Şablon, <code>msDS-OIDToGroupLink</code> bağlantılı bir "issuance policy" ile belirli bir gruba otomatik üyelik veriyor – bu bağlantı yanlış yapılandırılmışsa ayrıcalık kazandırıyor	Issuance policy grup eşlemesi
ESC14	Güçlü eşleme (<code>altSecurityIdentities</code>) alanının zayıf/çelişkili girdilerle manipülasyonu	Zayıf explicit mapping

(Not: ESC numaraları topluluk araştırmasıyla evrilmeye devam etmektedir; bu tablo yayın tarihi itibarıyla genel kabul görmüş sınıflandırmayı yansıtır.)

En Kritik ve En Yaygın: ESC1

ESC1, sahada en sık karşılaşılan ve en yıkıcı senaryodur çünkü tespiti ve istismarı basittir: bir şablon, düşük ayrıcalıklı kullanıcıların enrollment hakkına sahip olduğu, `ENROLLEE_SUPPLIES_SUBJECT` bayrağının (talep

eden kişinin SAN alanını kendi belirleyebilmesi) açık olduğu ve **Client Authentication** EKU'suna sahip olduğu şekilde yapılandırılmışsa, herhangi bir kullanıcı kendi adına değil **istediği herhangi bir kullanıcı adına** (SAN'a **administrator@corp.local** yazarak) sertifika talep edebilir ve bu sertifikayla PKINIT üzerinden o kullanıcı gibi kimlik doğrulayabilir.

Riskler ve Tehditler

Saha Gerçekleri

AD CS kurulu ortamların büyük çoğunluğunda en az bir ESC senaryosu (özellikle ESC1 veya ESC8) bulunur — çünkü varsayılan şablonlar (**WebServer**, özel klonlanmış şablonlar) genellikle güvenlik farkındalığı olmadan yapılandırılır ve "çalışıyor, dokunmayalım" mantığıyla yıllarca değiştirilmez.

Güvenlik Riskleri

- CA'nın kendisi Tier 0 olarak sınıflandırılmadığında, CA sunucusuna yerel admin erişimi olan herkes fiilen domain'i ele geçirebilir (özel anahtara erişerek herhangi bir sertifika imzalayabilir).
- ESC8 (NTLM relay), ağdaki herhangi bir noktadan (kimlik doğrulama gerektirmeden coercion teknikleriyle birleştirildiğinde) CA'ya ulaşılabilirse domain çapında risk oluşturur.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Steal or Forge Authentication Certificates	T1649	ESC1-14 senaryolarının genel karşılığı
Forge Web Credentials	T1606 (ilişkili)	Sahte sertifika ile kimlik doğrulama

Savunma Yöntemleri

1. **Şablon envanterini çıkarın ve **ENROLLEE_SUPPLIES_SUBJECT** + Client Auth EKU kombinasyonunu tarayın** (Certipy, PSPKIAudit gibi araçlarla) — bu kombinasyon ESC1'in doğrudan işaretidir.
2. **Düşük ayrıcalıklı kullanıcılara enrollment hakkı veren şablonları kısıtlayın** — **Domain Users** / **Authenticated Users** gibi geniş gruplara enrollment hakkı vermeyin.
3. **CA'yı **EDITF_ATTRIBUTESUBJECTALTNAME2** bayrağı için denetleyin** (**certutil -getreg policy\EditFlags**) — açksa kapatın.
4. **AD CS Web Enrollment'ı (HTTP) devre dışı bırakın veya HTTPS + Extended Protection for Authentication (EPA) ile koruyun** — ESC8'i kapatır.
5. **CA sunucusunu ve tüm PKI AD objelerini Tier 0 olarak sınıflandırın** — yerel admin erişimini Tier 0 hijyen kurallarıyla (Bölüm 3) kısıtlayın.
6. **msDS-KeyCredentialLink ve altSecurityIdentities alanlarını düzenli denetleyin** — Shadow Credentials benzeri tekniklerin (bu bölümün kapsamı dışında ama ilişkili) izlerini taşıır.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	PKI Yöneticisi	Güvenlik Ekibi	CISO
Şablon denetimi (Certipy/PSPKIAudit)	R	A	I
CA bayrak/yapılandırma denetimi	R	C	I
CA'nın Tier 0 sınıflandırması	C	R	A

Standart Eşleştirmesi

- **NIST SP 800-57** – anahtar yönetimi ve PKI en iyi uygulamaları.
- **CIS Benchmark** – AD CS ile ilgili spesifik kontroller (güncel sürümlerde genişletiliyor).

Gerçek Dünya Senaryosu: Klonlanmış Şablonun Bedeli

Bir kurumda, eski bir VPN çözümü için yıllar önce oluşturulmuş özel bir sertifika şablonu, varsayılan `User` şablonundan klonlanmıştı ve klonlama sırasında `ENROLLEE_SUPPLIES_SUBJECT` bayrağı yanlışlıkla açık bırakılmıştı. Şablon `Authenticated Users` grubuna enrollment hakkı veriyordu. Bir pentest ekibi, standart bir kullanıcı hesabıyla bu şablonu kullanarak Domain Admin adına sertifika talep etti ve PKINIT ile doğrudan Domain Admin olarak kimlik doğruladı – hiçbir parola kırma veya ACL zinciri gerekmedi. **Ders:** Şablon klonlama, güvenlik bayraklarının kopyalanıp kopyalanmadığının açıkça doğrulanmasını gerektirir.

Kontrol Listesi

- ☐ Tüm sertifika şablonları ESC1-14 açısından tarandı mı (Certipy/PSPKIAudit ile)?
- ☐ `ENROLLEE_SUPPLIES_SUBJECT` + Client Auth ECU kombinasyonuna sahip şablon var mı?
- ☐ CA `EDITF_ATTRIBUTESUBJECTALTNAME2` bayrağı kapalı mı?
- ☐ Web Enrollment (HTTP) devre dışı veya EPA ile korunuyor mu?
- ☐ CA sunucusu ve PKI objeleri Tier 0 olarak sınıflandırıldı mı?
- ☐ Düşük ayrıcalıklı gruplara geniş enrollment hakkı veren şablon var mı?

Bölüm Özeti

AD CS, doğru yapılandırıldığında güçlü bir kimlik doğrulama altyapısıdır; yanlış yapılandırıldığında ise Kerberoasting veya ACL zincirlerinden bile daha hızlı bir Domain Admin yoludur. ESC1 ve ESC8, sahada en

sık görülen ve en kolay istismar edilen senaryolardır — bu ikisinin kapatılması, en yüksek risk azaltımını en düşük çabayla sağlar.

Sahada Dikkat Edilecek Noktalar

- Şablon klonlama işlemlerini her zaman güvenlik bayrakları açısından yeniden gözden geçirin.
- CA'nın kendisini Tier 0 dışında bırakmak, tüm diğer Tier 0 kontrollerini anlamsız kılar.

Ek Okuma

- SpecterOps, "Certified Pre-Owned: Abusing Active Directory Certificate Services"
- Certipy resmi dokümantasyonu (ESC istismar/tespit araçları)

Kaynakça

1. SpecterOps, *Certified Pre-Owned* whitepaper (2021)
 2. Certipy Project, GitHub dokümantasyonu
 3. Microsoft Learn, *Active Directory Certificate Services Overview*
-

Bölüm 7 — Delegasyon (Constrained/Unconstrained/RBCD)

Giriş

Kerberos delegasyonu, bir hizmetin bir kullanıcı adına başka bir hizmete erişmesine izin veren meşru bir mekanizmadır (örn. bir web sunucusunun, kullanıcı adına bir veritabanına bağlanması). Ancak yanlış yapılandırıldığında, delegasyon AD'nin en güçlü ayrıcalık yükseltme vektörlerinden birine dönüşür.

Öğrenme Hedefleri

- Unconstrained, Constrained ve Resource-Based Constrained Delegation (RBCD) arasındaki farkları açıklayabilmek.
- Her delegasyon türünün istismar senaryosunu ve ön koşulunu bilmek.
- Güvenli delegasyon yapılandırması için pratik kontrolleri uygulayabilmek.

Temel Kavramlar

Unconstrained Delegation, bir hizmet hesabına (`TRUSTED_FOR_DELEGATION` bayrağı) tanındığında, o hizmete bağlanan **her kullanıcının TGT'sinin bir kopyasının** hizmet sunucusunun belleğinde saklanmasına izin verir — hizmet bu TGT'leri kullanarak kullanıcı adına **herhangi bir** başka hizmete erişebilir. Bu, sınırsız bir güç devridir.

Constrained Delegation (`TRUSTED_TO_AUTH_FOR_DELEGATION` ile birlikte `msDS-AllowedToDelegateTo`), bir hizmetin kullanıcı adına **sadece belirtilen hedef hizmetlere** erişebilmesini sağlar — Unconstrained'a göre çok daha güvenlidir ama hedef listesi doğru sınırlandırılmazsa yine de risklidir.

Resource-Based Constrained Delegation (RBCD), Windows Server 2012'de tanıtılan, kontrolü **kaynak tarafına** (hedef hizmete) veren bir modeldir: hedef hizmet, `msDS-AllowedToActOnBehalfOfOtherIdentity` özniteliği aracılığıyla "hangi hesapların benim adıma delegasyon yapabileceğini ben belirlerim" der. Bu, kaynak objesi üzerinde yazma hakkı olan **herhangi birinin** kendini delegasyon zincirine ekleyebilmesi anlamına gelir — bu nedenle Bölüm 5'teki ACL kötüye kullanımıyla doğrudan kesişir.

Teknik Arka Plan

Unconstrained Delegation İstismarı

Bir saldırgan, `TRUSTED_FOR_DELEGATION` bayraklı bir sunucuda yerel admin yetkisi elde ederse, o sunucuya bağlanan **herhangi bir** ayrıcalıklı kullanıcının (örn. bir Domain Admin, sorun giderme amacıyla o sunucuya RDP ile bağlandığında) TGT'sini bellekte yakalayabilir. Bu, saldırganın o Domain Admin'in tam yetkisiyle hareket etmesini sağlar. Klasik istismar zinciri: coercion teknikleri (örn. PrinterBug/PetitPotam ile bir DC'yi

zorla bağlanmaya zorlamak) ile bu tekniği birleştirmek, DC'nin makine hesabı TGT'sini yakalamayı ve doğrudan DCSync yapmayı mümkün kılar.

Constrained Delegation İstismarı

`msDS-AllowedToDelegateTo` listesi çok genişse (örn. bir hizmete "herhangi bir SPN'e delegasyon" izni verilmişse) veya **protokol geçişi (protocol transition, `TRUSTED_TO_AUTH_FOR_DELEGATION`)** etkinse, saldırgan bu hizmet hesabının kimlik bilgisini ele geçirdiğinde, S4U2Self/S4U2Proxy uzantılarını kullanarak **herhangi bir kullanıcı adına** (parolasını bilmeden) hedef hizmete bilet üretebilir. Yüksek riskli durum: `msDS-AllowedToDelegateTo` listesinde bir DC'nin `LDAP` SPN'i varsa, bu doğrudan DCSync'e açılan bir kapıdır.

RBCD İstismarı

Saldırgan, bir bilgisayar objesi üzerinde `GenericWrite / WriteProperty` hakkına sahipse (Bölüm 5'te işlenen ACL kötüye kullanımı ile), o objenin `msDS-AllowedToActOnBehalfOfOtherIdentity` özneliğine **kendi kontrolündeki bir bilgisayar hesabını** ekleyebilir. Ardından, kendi kontrolündeki bu hesabın kimlik bilgisiyle S4U2Self/S4U2Proxy zincirini kullanarak hedef bilgisayarda **herhangi bir kullanıcı** (Domain Admin dahil) adına bilet üretilip erişim sağlayabilir. RBCD'nin özellikle tehlikeli olmasının nedeni: varsayılan olarak her authenticated kullanıcı, kendi oluşturduğu bilgisayar objeleri üzerinde (`ms-DS-MachineAccountQuota` sayesinde, varsayılan 10) tam kontrole sahiptir — yani saldırgan kendi sahte bilgisayar hesabını oluşturup RBCD zincirinde kullanabilir.

Riskler ve Tehditler

Saha Gerçekleri

Unconstrained Delegation, eski (Windows 2000/2003 döneminden kalma) uygulama sunucularında sıkça hâlâ etkindir çünkü "bir zamanlar gerekliydi, kaldırırsak bir şey bozulur mu bilmiyoruz" korkusuyla dokunulmaz. RBCD istismarı ise `ms-DS-MachineAccountQuota` varsayılan değeri (10) sıfırlanmadığı sürece **her authenticated kullanıcı için** mümkündür.

Güvenlik Riskleri

- Unconstrained Delegation + coercion (PrinterBug/PetitPotam) kombinasyonu, düşük ayrıcalıklı bir başlangıç noktasından doğrudan DC ele geçirmeye götürebilir.
- `ms-DS-MachineAccountQuota` sıfırlanmadığı sürece, RBCD saldırı yüzeyi teorik olarak **her kullanıcıya açıktır**, özel bir izin gerekmez.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Use Alternate Authentication Material	T1550 (ilişkili alt teknikler)	Delegasyon üzerinden bilet manipülasyonu
Steal or Forge Kerberos Tickets	T1558	S4U2Self/S4U2Proxy istismarı
Exploitation for Privilege Escalation	T1068 (ilişkili)	RBCD zinciri

Savunma Yöntemleri

1. **Unconstrained Delegation'ı ortamınızdan tamamen kaldırın** (DC'ler doğası gereği hariç) — `Get-ADComputer -Filter {TrustedForDelegation -eq $true}` ile tarayın, gerekmeyen her yerde kapatın.
2. **Constrained Delegation listelerini minimum tutun ve protokol geçişini yalnızca gerçekten gerekliyse etkinleştirin.**
3. **ms-DS-MachineAccountQuota** değerini 0'a düşürün (özel bir süreçle, gerekçelendirilmiş bilgisayar eklemeleri yönetici tarafından yapılsın):

```
Set-ADDomain -Identity corp.local -Replace @{"ms-DS-MachineAccountQuota"="0"}
```

4. **Ayrıcalıklı hesapları "Account is sensitive and cannot be delegated" bayrağıyla işaretleyin** — bu bayrak, hesabın herhangi bir delegasyon türüne (unconstrained/constrained) konu olmasını engeller; Domain Admins/Protected Users grubu üyeleri için varsayılan olarak uygulanmalıdır (bkz. Bölüm 10).
5. **Coercion tekniklerine karşı savunun** — PrinterBug/PetitPotam gibi tekniklerin dayandığı RPC arayüzlerini (MS-RPRN, MS-EFSR) DC'lerde gereksizse kapatın, RPC filtering uygulayın.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	Uygulama Sahipleri
Unconstrained Delegation temizliği	R	A	C
MachineAccountQuota sıfırlama	R	C	I
Protected Users grubu ataması	R	A	I

Standart Eşleştirmesi

- **CIS Benchmark** — Kerberos delegasyon kontrolleri.
- **NIST SP 800-53** — AC-6 (Least Privilege).

Gerçek Dünya Senaryosu: Eski Raporlama Sunucusu

Bir kurumda, 2009'da kurulmuş bir raporlama sunucusu hâlâ Unconstrained Delegation ile yapılandırılıyordu. Bir pentest ekibi bu sunucuda yerel admin yetkisi elde etti, ardından PetitPotam tekniğiyle DC'yi bu sunucuya zorla kimlik doğrulamayı başardı. DC'nin makine hesabı TGT'si yakalandı ve bu bilet ile DCSync gerçekleştirilerek KRBTGT dahil tüm domain hash'leri ele geçirildi – tüm süreç 20 dakikadan kısa sürdü.

Ders: "Eski ama çalışıyor" sunucular, en yüksek risk taşıyan varlıklardır; Unconstrained Delegation taraması düzenli olmalıdır.

Kontrol Listesi

- ☐ Unconstrained Delegation bayraklı, DC olmayan sunucu var mı?
- ☐ Constrained Delegation listeleri (`msDS-AllowedToDelegateTo`) gereğinden geniş mi?
- ☐ `ms-DS-MachineAccountQuota` 0'a düşürüldü mü?
- ☐ Domain Admins/Protected Users üyeleri "cannot be delegated" bayrağıyla işaretli mi?
- ☐ Coercion tekniklerine karşı RPC filtering/karşı önlem uygulandı mı?

Bölüm Özeti

Delegasyon türlerinin her biri farklı bir güven modeli sunar – Unconstrained en tehlikelisi, RBCD ise ACL kötüye kullanımıyla en kolay zincirlenebilenidir. `ms-DS-MachineAccountQuota` gibi tek bir varsayılan değerın sınırlanması, RBCD saldırı yüzeyinin büyük kısmını tek başına kapatabilir – bu, düşük çabayla yüksek etki sağlayan nadir kontrollerden biridir.

Sahada Dikkat Edilecek Noktalar

- Unconstrained Delegation'ı "sonra kaldırırız" diye ertelemeyin – coercion teknikleriyle birleştğinde en hızlı DC ele geçirme yollarından biridir.
- `ms-DS-MachineAccountQuota` sınırlaması, en ucuz ve en etkili tek kontrollerden biridir.

Ek Okuma

- Microsoft Learn: "Kerberos Constrained Delegation Overview"
- Elad Shamir, "Wagging the Dog: Abusing Resource-Based Constrained Delegation"

Kaynakça

1. Microsoft Learn, *Kerberos Constrained Delegation*
 2. Elad Shamir, *Wagging the Dog* (RBCD araştırması, 2019)
 3. MITRE ATT&CK, T1558 alt teknikleri
-

Bölüm 8 – GPO Güvenliği

Giriş

Group Policy Objects (GPO), binlerce bilgisayara aynı anda ayar veya betik dağıtabilen güçlü bir mekanizmadır – ve tam da bu güç nedeniyle, bir GPO'yu kontrol etmek fiilen o GPO'nun uygulandığı her sistemde kod çalıştırma yetkisine sahip olmak demektir. Bu bölüm, GPO'nun hem saldırı hem savunma yüzü olarak nasıl ele alınması gerektiğini işler.

Öğrenme Hedefleri

- GPO'nun neden fiilen bir "kod çalıştırma" mekanizması olduğunu açıklayabilmek.
- GPP (Group Policy Preferences) parola sızıntısı zafiyetini ve güncel karşılığını bilmek.
- GPO delegasyon hatalarını ve güvenli GPO tasarım ilkelerini uygulayabilmek.

Temel Kavramlar

GPO, bir OU/domain/site'a bağlanan (link), o kapsamdaki tüm kullanıcı/bilgisayarlara ayar, betik veya yazılım dağıtan bir politika objesidir. GPO'nun kendisi bir AD objesidir ve dolayısıyla kendi ACL'ine sahiptir (Bölüm 5 ile doğrudan ilişkili).

GPP (Group Policy Preferences), Windows Server 2008'de tanıtılan, GPO üzerinden yerel kullanıcı/parola, drive mapping, zamanlanmış görev gibi ayarları dağıtabilen bir uzantıdır. Tarihsel olarak, GPP ile dağıtılan parolalar SYSVOL'da **AES ile şifrelenmiş ama genel bir Microsoft anahtarıyla** saklanıyordu (MS14-025 ile "düzeltildi" – yeni GPP parola oluşturma engellendi, ama eski XML dosyaları temizlenmediyse hâlâ sahada bulunur).

GPO Uygulama Sırası (LSDOU): Local → Site → Domain → OU (en yakın OU en son ve en yüksek öncelikte uygulanır) – bu sıra, çakışan ayarların hangisinin kazanacağını belirler ve delegasyon hatalarının etkisini anlamak için bilinmesi gerekir.

Teknik Arka Plan

GPO'nun Kod Çalıştırma Mekanizması Olarak Kullanımı

Bir GPO, **Computer Configuration > Windows Settings > Scripts** (startup/shutdown) veya **User Configuration** altında logon/logoff betikleri tanımlayabilir. Bir saldırgan, bir GPO üzerinde yazma hakkı elde ederse (doğrudan veya Bölüm 5'teki ACL zinciriyle), bu GPO'nun uygulandığı **her** bilgisayarda/kullanıcıda istediği kodu çalıştırabilir – bu, DC'lere uygulanan bir GPO söz konusu olduğunda **doğrudan Domain Admin** anlamına gelir.

GPP Parola Sızıntısı

Groups.xml, **Services.xml**, **ScheduledTasks.xml** gibi GPP dosyaları, SYSVOL paylaşımında (her authenticated kullanıcının okuyabildiği) saklanır. MS14-025 öncesi oluşturulmuş XML dosyalarında

`cpassword` alanı bulunuyorsa, bu değer **genel olarak bilinen sabit bir AES anahtarıyla** çözülebilir — bu anahtar Microsoft dokümantasyonunda yayınlanmıştır (yani "şifreleme" güvenlik sağlamaz). Bu teknik hâlâ SYSVOL taramasında en hızlı "quick win"lerden biridir.

```
# SYSVOL'da cpassword içeren GPP dosyalarını tarama (savunma amaçlı)
Get-ChildItem -Path "\\corp.local\SYSVOL" -Recurse -Include *.xml -ErrorAction SilentlyContinue |
    Select-String -Pattern "cpassword" | Where-Object { $_.Line -notmatch 'cpassword=""' }
```

GPO Delegasyon Hataları

Bir GPO'nun `gPCFileSysPath` (SYSVOL'daki dosya konumu) ve AD'deki `groupPolicyContainer` objesi ayrı ACL'lere sahiptir. Bazı yanlış yapılandırmalarda, GPO'nun AD objesi doğru kısıtlanmışken SYSVOL'daki dosya sistemi ACL'i daha gevşek bırakılır (veya tam tersi) — bu tutarsızlık, "GPO düzenleme yetkisi yok ama SYSVOL'daki betik dosyasını değiştirebiliyorum" gibi ilginç ama tehlikeli senaryolara yol açabilir.

"Düşük Ayrıcalıklı Kullanıcı GPO Oluşturabilir mi" Sorunu

Varsayılan olarak, `Group Policy Creator Owners` grubu üyeleri yeni GPO oluşturabilir (ama var olan bir GPO'yu domain'e link edemez — bu ayrı bir hak gerektirir). Ancak bu grup üyeliği genellikle unutulur; kullanıcı artık o rolde olmasa bile grup üyeliğinden çıkarılmamış olabilir.

Riskler ve Tehditler

Saha Gerçekleri

SYSVOL taramaları, özellikle 2015 öncesinden beri var olan AD ortamlarında sıkça `cpassword` içeren GPP dosyaları bulur — bu dosyalar genellikle kimse tarafından hatırlanmayan, eski bir yerel admin parolası dağıtımından kalmıştır.

Güvenlik Riskleri

- Bir GPO üzerindeki yazma hakkı, o GPO'nun kapsamındaki tüm sistemlerde kod çalıştırma anlamına gelir — bu, ACL kötüye kullanımının (Bölüm 5) en doğrudan sonuçlarından biridir.
- GPP `cpassword` sızıntısı, tek bir SYSVOL taramasıyla anında yerel admin/hizmet hesabı parolası elde etmeyi sağlayabilir.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Valid Accounts	T1078	GPP'den elde edilen parolalarla kimlik doğrulama
Unsecured Credentials: Group Policy Preferences	T1552.006	GPP <code>cpassword</code> hasadı
Domain Policy Modification: Group Policy Modification	T1484.001	GPO manipülasyonu ile kod çalıştırma/ayrıcalık yükseltme

Savunma Yöntemleri

1. SYSVOL'u **cpassword** için periyodik tarayın ve bulunan her XML dosyasını silin, ilgili parolaları rotasyona sokun.
2. GPO ACL'lerini **AdminSDHolder** mantığıyla benzer titizlikte denetleyin — kim GPO oluşturabilir, kim var olan GPO'ları düzenleyebilir, kim GPO'ları OU'lara link edebilir sorularını ayrı ayrı yanıtlayın.
3. **Group Policy Creator Owners** grubunu boş tutun, GPO oluşturma ihtiyacını JIT (Just-In-Time, Bölüm 10) süreciyle karşılayın.
4. Tier 0 GPO'larını (DC'lere uygulanan) ayrı bir onay/değişiklik yönetimi sürecine bağlayın — bu GPO'lar için düzenleme yetkisi sadece Tier 0 yöneticilerinde olmalıdır.
5. GPO değişikliklerini izleyin — Event ID 5136 (dizin objesi değişikliği) GPO objelerinde filtrelenerek SIEM'e bağlanmalıdır (bkz. Bölüm 12).

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
SYSVOL/GPP taraması	R	A	I
GPO ACL denetimi	R	C	I
Tier 0 GPO değişiklik yönetimi	R	A	I

Standart Eşleştirmesi

- **CIS Benchmark** — Group Policy ile ilgili spesifik kontroller.
- **NIST SP 800-53** — CM-3 (Configuration Change Control).

Gerçek Dünya Senaryosu: 2011'den Kalma cpassword

Bir kurumda SYSVOL taraması, 2011'de oluşturulmuş ve o zamandan beri hiç silinmemiş bir **Groups.xml** dosyasında **cpassword** alanı buldu. Değer çözüldüğünde, bu parolanın **hâlâ geçerli** bir yerel admin parolası olduğu ve organizasyondaki yüzlerce iş istasyonunda **aynı** parolayla kullanıldığı ortaya çıktı (LAPS henüz uygulanmamıştı). Bir saldırgan, tek bir SYSVOL okuma erişimiyle yüzlerce sistemde yerel admin olabilirdi. **Ders:** MS14-025 sadece yeni GPP parola oluşturmaya engeller, var olan eski dosyaları temizlemez — bu manuel bir denetim gerektirir.

Kontrol Listesi

- ☐ SYSVOL'da **cpassword** içeren GPP dosyası var mı?

- ☐ `Group Policy Creator Owners` grubu boş mu?
- ☐ Tier 0 GPO'larının düzenleme yetkisi sadece Tier 0 yöneticilerinde mi?
- ☐ GPO objesi ACL'i ile SYSVOL dosya sistemi ACL'i tutarlı mı?
- ☐ GPO değişiklikleri için SIEM/log izleme aktif mi (Event ID 5136)?

Bölüm Özeti

GPO, AD'nin en güçlü merkezi yönetim aracıdır ve bu güç, yanlış ellerde en hızlı domain genelinde kod çalıştırma yoludur. GPP `cpassword` sızıntısı, on yılı aşkın süredir bilinen ama hâlâ sahada bulunan bir "quick win"dir — tek bir SYSVOL taraması, bu bölümdeki en yüksek getirili kontroldür.

Sahada Dikkat Edilecek Noktalar

- "MS14-025 yamalandı, güvendedeyiz" varsayımı yanlıştır — yama sadece yeni oluşturmayı engeller.
- GPO ACL'lerini ACL kötüye kullanımı (Bölüm 5) denetiminden ayrı düşünmeyin, aynı sürecin parçası olmalı.

Ek Okuma

- Microsoft Security Bulletin MS14-025
- Microsoft Learn: "Group Policy Preferences Overview"

Kaynakça

1. Microsoft, *MS14-025 Security Bulletin*
2. Microsoft Learn, *Group Policy Preferences*
3. MITRE ATT&CK, T1552.006

Bölüm 9 — Trust'lar & Forest Sınırları

Giriş

Trust ilişkileri, farklı domain/forest'ların birbirine kimlik doğrulama güveni tanımasını sağlar. Bölüm 1'de vurgulandığı gibi forest gerçek güvenlik sınırıdır — ama bir trust kurulduğunda, bu sınır kısmen (bazen fazlasıyla) delinir. Bu bölüm, trust türlerini ve bunların istismar/savunma boyutlarını ele alır.

Öğrenme Hedefleri

- Trust türlerini (parent-child, tree-root, forest, external, shortcut, realm) ve yön/geçişkenlik özelliklerini ayırt edebilmek.
- SID filtering ve neden kritik olduğunu açıklayabilmek.
- Trust güvenliği için pratik denetim adımlarını uygulayabilmek.

Temel Kavramlar

Trust yönü: Tek yönlü (A, B'ye güvenir — B'deki kullanıcılar A'daki kaynaklara erişebilir, tersi değil) veya iki yönlü olabilir.

Geçişkenlik (transitivity): Bir forest içindeki tüm domain'ler arasındaki trust'lar (parent-child, tree-root) otomatik olarak geçişkendir — A, B'ye güvenir ve B, C'ye güvenirse, A da C'ye güvenir. **External trust'lar geçişkin değildir;** sadece iki spesifik domain arasında geçerlidir. **Forest trust'lar** varsayılan olarak geçişkendir ama forest sınırında durur (bir forest'teki her domain, karşı forest'teki her domaine güvenir, ama üçüncü bir forest'e otomatik yayılmaz).

SID Filtering, forest/external trust'larda varsayılan olarak etkin olan bir güvenlik mekanizmasıdır: karşı taraftan gelen bir kimlik doğrulama talebinde, talep eden domain'in **kendi SID aralığı dışında** bir SID (özellikle **SID History** alanında taşınan bir SID) varsa, bu SID'ler filtrelenir/reddedilir. Bu, "SID History enjeksiyonu" ile bir domain'den güvenilen forest'te ayrıcalıklı bir SID'i taklit etmeyi engeller.

Teknik Arka Plan

SID History Enjeksiyonu ve SID Filtering'in Rolü

Bir domain içinde (aynı forest, parent-child trust) SID filtering **varsayılan olarak devre dışıdır** çünkü SID History, meşru domain migrasyon senaryolarında kullanıcının eski domain'deki erişimini yeni domain'de korumak için tasarlanmıştır. Ancak bu, aynı forest içinde bir domain'i ele geçiren bir saldırganın (child domain gibi görece daha zayıf korunan bir domain), kendi kontrolündeki bir hesabın SID History alanına **parent domain'in Enterprise Admins SID'ini enjekte ederek** forest çapında ayrıcalık kazanabileceği anlamına gelir. Bu, **"child domain her zaman parent domain'i tehlikeye atabilir"** ilkesinin teknik temelidir — bu nedenle Microsoft, çok domainli bir forest'te her domain'in aslında forest'in tamamıyla aynı güven seviyesinde ele alınması gerektiğini vurgular.

Forest ve external trust'larda SID filtering varsayılan olarak **etkindir** ve bu, yukarıdaki senaryoyu forest sınırında engeller — ancak bazı yöneticiler, "eski uygulama uyumluluğu" gerekçesiyle SID filtering'i **kasıtlı olarak kapatır** (`netdom trust /quarantine:no`), bu da forest sınırını fiilen ortadan kaldırır.

TGT Delegation ve Trust Üzerinden Kerberos Delegasyonu

Forest trust'larda, "Kerberos authentication delegation'a izin ver" seçeneği açıksa, bir domaindeki hizmetler karşı forest'teki kullanıcılar adına delegasyon yapabilir — bu, Bölüm 7'deki delegasyon risklerinin trust sınırına taşınmış halidir ve genellikle gereksiz yere açık bırakılır.

External Trust'ların Özel Riski

External trust'lar (forest trust yerine tek domain-to-domain), genellikle eski migrasyon projelerinden veya iş ortağı entegrasyonlarından kalır ve **SID filtering varsayılan olarak açık olsa da**, geçişkin olmadıkları için haritalanması/envanteri kolayca unutulur — "bu trust hâlâ neden var, kim kullanıyor" sorusunun cevabı çoğu zaman bilinmez.

Riskler ve Tehditler

Saha Gerçekleri

Çok domainli forest'larda, "child domain daha az kritik" varsayımı çok yaygındır ve child domain'ler genellikle parent domain'den daha gevşek güvenlik kontrolleriyle yönetilir — bu varsayım, SID History enjeksiyonu riski nedeniyle **teknik olarak yanlıştır**.

Güvenlik Riskleri

- SID filtering kapatılmış bir trust, forest sınırını fiilen ortadan kaldırır.
- Unutulmuş external trust'lar, kimsenin sahiplenmediği, düzenli denetlenmeyen bir saldırı yüzeyi oluşturur.
- Forest trust'larda gereksiz yere açık bırakılmış Kerberos delegasyon izni, Bölüm 7'deki riskleri trust sınırına taşır.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Domain Trust Discovery	T1482	Trust haritalama/keşif
SID-History Injection	T1134.005	Ayrıcalıklı SID taklit etme

Savunma Yöntemleri

1. Trust envanterini çıkarın ve her trust için "neden var, kim sahiplenir, ne zaman gözden geçirilecek" sorularını yanıtlayın — `Get-ADTrust -Filter *` ile başlayın.
2. Kullanılmayan/gerekçesi olmayan trust'ları kaldırın.

3. SID filtering'in tüm forest/external trust'larda etkin olduğunu doğrulayın (`netdom trust /domain:<trust> /quarantine` ile kontrol edin) – kasıtlı olarak kapatılmış bir trust varsa bunun iş gerekçesini belgeleyin ve riski kabul edin.
4. Çok domainli bir forest'te her domain'i Tier 0 hijyeni ile yönetin – "child domain daha az önemli" varsayımını terk edin.
5. Forest trust'larda Kerberos delegasyonunu yalnızca gerçekten gerekliyse açın.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
Trust envanteri ve gözden geçirme	R	A	I
SID filtering doğrulama	R	C	I
Gereksiz trust kaldırma	R	A	I

Standart Eşleştirmesi

- NIST SP 800-53 – SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement).

Gerçek Dünya Senaryosu: Kapatılmış SID Filtering

Bir kurum, eski bir ERP uygulamasının "cross-domain SID uyumluluğu" gerektirdiği gerekçesiyle iki domain arasındaki trust'ta SID filtering'i kapatmıştı – bu karar 8 yıl önce alınmış ve hiç gözden geçirilmemişti. Bir güvenlik değerlendirmesinde, daha az kritik kabul edilen domain'in ele geçirilmesi durumunda, SID History enjeksiyonu ile ana domain'de Enterprise Admin yetkisi kazanılabileceği gösterildi. ERP uygulaması incelendiğinde, SID filtering'e gerçekte hiç ihtiyacı olmadığı, kararın yanlış bir varsayıma dayandığı ortaya çıktı. **Ders:** Güvenlik özelliklerini kapatma kararları zaman damgalı gerekçe ve düzenli yeniden değerlendirme gerektirir.

Kontrol Listesi

- ☐ Trust envanteri güncel mi, her trust'ın iş gerekçesi belgeli mi?
- ☐ SID filtering tüm forest/external trust'larda etkin mi?
- ☐ Kullanılmayan trust'lar kaldırıldı mı?
- ☐ Çok domainli forest'te tüm domain'ler aynı hijyen seviyesiyle mi yönetiliyor?
- ☐ Forest trust'larda Kerberos delegasyonu sadece gerekli olduğunda mı açık?

Bölüm Özeti

Trust ilişkileri, forest sınırının kontrollü şekilde delinmesidir ve bu delinme her zaman SID filtering gibi mekanizmalarla dengelenmelidir. Çok domainli forest'lerde "her domain forest'in tamamı kadar kritiktir" ilkesi, SID History enjeksiyonu riskinin doğal sonucudur.

Sahada Dikkat Edilecek Noktalar

- SID filtering'i kapatma kararlarını asla kalıcı kabul etmeyin, düzenli yeniden değerlendirin.
- Unutulmuş trust'lar, unutulmuş ACL'ler kadar tehlikelidir – envanterden düşmeyin.

Ek Okuma

- Microsoft Learn: "How Domain and Forest Trusts Work"
- Sean Metcalf, ADSecurity.org – "Trust" ile ilgili yazı dizisi

Kaynakça

1. Microsoft Learn, *How Trusts Work*
2. Microsoft Learn, *SID Filtering and Trusted Domain Objects*
3. MITRE ATT&CK, T1482, T1134.005

Bölüm 10 — Kimlik Bilgisi Hijyeni & PAM/JIT

Giriş

Bölüm 3'te tanımlanan credential exposure prevention ilkesinin operasyonel uygulaması bu bölümde işlenir. Kimlik bilgisi hijyeni, tek bir araç veya ayar değil, sürekli bir disiplindir; PAM/PIM ve JIT (Just-In-Time) erişim modelleri bu disiplini teknik kontrollerle destekler.

Öğrenme Hedefleri

- Credential hijyeninin temel bileşenlerini (Protected Users, standing privilege azaltma) tanımlayabilmek.
- PAM/PIM ve JIT erişim modellerinin nasıl çalıştığını açıklayabilmek.
- Kalıcı (standing) ayrıcalığın neden başlı başına bir risk olduğunu bilmek.

Temel Kavramlar

Standing privilege, bir hesabın **sürekli olarak** ayrıcalıklı bir grup üyeliğine (örn. Domain Admins) sahip olmasıdır — ihtiyaç anında değil, her zaman. Standing privilege, saldırı yüzeyini genişletir çünkü o hesabın kimlik bilgisi ele geçirildiği **her an** ayrıcalıklı erişim sağlar.

JIT (Just-In-Time) erişim, ayrıcalığın yalnızca ihtiyaç anında, sınırlı bir süre için ve genellikle bir onay sürecinden geçerek verilmesidir. İhtiyaç bittiğinde ayrıcalık otomatik olarak geri alınır.

PAM (Privileged Access Management) / PIM (Privileged Identity Management), standing privilege'ı JIT modele dönüştüren, kimlik bilgilerini vault'ta saklayan/rotasyon eden, erişim taleplerini onaya bağlayan ve tüm ayrıcalıklı oturumları kaydeden sistemlerdir (örn. Microsoft Entra PIM, CyberArk, BeyondTrust).

Protected Users grubu (Windows Server 2012 R2+), üyelerine NTLM kimlik doğrulamasını, DES/RC4 Kerberos şifrelemesini, delegasyonu ve önbelleğe alınmış kimlik bilgisini (uzun süreli) devre dışı bırakan özel bir güvenlik grubudur — bu grup, Bölüm 4 ve 7'de işlenen birçok saldırı yüzeyini tek bir grup üyeliğiyle kapatır.

Teknik Arka Plan

Protected Users'ın Getirdiği Kısıtlamalar

Bir hesap Protected Users grubuna eklendiğinde: - NTLM kimlik doğrulaması kullanılamaz (sadece Kerberos). - Kerberos'ta DES veya RC4 şifreleme kullanılamaz (sadece AES). - Hesap herhangi bir delegasyon türüne (unconstrained/constrained) konu olamaz. - TGT ömrü kısaltılır ve yenilenemez hale gelir (varsayılan olarak 4 saat, `msDS-MaximumTicketAge` ile ayarlanabilir) — bu, çalınan bir TGT'nin kullanım penceresini önemli ölçüde daraltır. - Kimlik bilgisi, host üzerinde uzun süreli önbelleğe alınmaz (offline logon için saklanmaz).

```
# Protected Users grubuna ekleme (Tier 0 hesapları için önerilir)
Add-ADGroupMember -Identity "Protected Users" -Members "adm0-jdoe"
```

Dikkat: Protected Users'a eklenen bir hesap NTLM'e ihtiyaç duyan eski bir uygulamayla kimlik doğrulayamaz hale gelebilir — bu grup, test edilmeden geniş ölçekte uygulanmamalıdır. Tier 0 hesapları için genellikle güvenle uygulanabilir çünkü bu hesaplar zaten sınırlı, iyi bilinen sistemlerde kullanılır.

Standing Privilege'dan JIT'e Geçiş

Klasik model: bir yönetici sürekli Domain Admins üyesidir. JIT model: yönetici normalde **hiçbir** ayrıcalıklı gruba üye değildir; bir işlem yapması gerektiğinde PAM/PIM sistemi üzerinden erişim talep eder, onaylanır (otomatik veya insan onayı ile), belirli bir süre (örn. 4 saat) için geçici grup üyeliği verilir, süre sonunda otomatik kaldırılır. Bu model, saldırı penceresini "her zaman açık" durumdan "sadece ihtiyaç anında açık" duruma indirir.

Just-Enough-Administration (JEA), JIT'in tamamlayıcısıdır: yöneticiye tam bir shell/RDP erişimi yerine, PowerShell üzerinden **sadece belirli komutları çalıştırma** yetkisi verir — örneğin bir help desk yöneticisi, sadece `Unlock-ADAccount` ve `Set-ADAccountPassword` komutlarını çalıştırabilir, başka hiçbir şeye erişemez.

Riskler ve Tehditler

Saha Gerçekleri

Çoğu kurumda Domain Admins üyeliği "kim ne zaman ekledi, hâlâ gerekli mi" sorusu sorulmadan yıllarca birikir. PAM/PIM projeleri genellikle "çok karmaşık, operasyonel sürtünme yaratır" gerekçesiyle ertelenir — ama bu erteleme, standing privilege riskinin sürmesi anlamına gelir.

Güvenlik Riskleri

- Standing privilege, saldırı penceresini maksimize eder — bir kimlik bilgisi hırsızlığı, günün her saatinde işe yarar.
- PAM/PIM sisteminin kendisi Tier 0'dır (Bölüm 3'te belirtildiği gibi) — yanlış konumlandırılırsa (örn. Tier 1 sistemde çalıştırılırsa) tüm modeli anlamsız kılar.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Valid Accounts	T1078	Standing privilege'lı hesapların ele geçirilmesi
Account Discovery	T1087	Ayrıcalıklı grup üyeliği keşfi

Savunma Yöntemleri

1. **Tüm Tier 0/1 yönetici hesaplarını Protected Users grubuna ekleyin** (test sonrası, aşamalı olarak).

2. **PAM/PIM projesine öncelik verin** – en azından Domain Admins/Enterprise Admins için standing membership'i kaldırıp JIT modele geçin.
3. **JEA ile help desk/Tier 2 yönetim görevlerini spesifik komutlarla sınırlayın.**
4. **Ayrıcalıklı grup üyeliklerini düzenli (aylık/üç aylık) gözden geçirin** – "hâlâ gerekli mi" sorusunu her üye için yanıtlayın.
5. **PAM/PIM sistemini Tier 0 olarak konumlandırın ve yönetin** (bkz. Bölüm 3).

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
Protected Users uygulaması	R	C	I
PAM/PIM projesi	C	R	A
Ayrıcalıklı grup gözden geçirme	R	A	I

Standart Eşleştirmesi

- **NIST SP 800-53** – AC-2 (Account Management), AC-6(1) (Authorize Access to Security Functions).
- **CIS Controls v8** – Control 5 ve 6 (Account/Access Control Management).

Gerçek Dünya Senaryosu: 47 Kişilik Domain Admins Grubu

Bir kurumda Domain Admins grubunda 47 üye bulunuyordu; bunların büyük çoğunluğu yıllar içinde "geçici" ihtiyaçlar için eklenmiş ve hiç çıkarılmamıştı. Bir güvenlik değerlendirmesi, bu üyelerin sadece 6'sının aktif olarak Domain Admin yetkisi gerektiren bir görevde olduğunu ortaya çıkardı. PAM/PIM projesi sonrası standing membership 3'e (acil durum "break-glass" hesapları) indirildi, geri kalan tüm ihtiyaçlar JIT modeline taşındı. Bu değişiklik tek başına, saldırı yüzeyini (potansiyel hedef sayısını) %94 azalttı. **Ders:** Standing privilege genellikle organizasyonel unutkanlığın, kötü niyetin değil, sonucudur – ama sonuç aynı derecede risklidir.

Kontrol Listesi

- ☐ Tier 0/1 yönetici hesapları Protected Users grubunda mı?
- ☐ Domain Admins/Enterprise Admins standing membership yerine JIT modeliyle mi yönetiliyor?
- ☐ PAM/PIM sistemi Tier 0 olarak sınıflandırıldı ve yönetiliyor mu?
- ☐ Ayrıcalıklı grup üyelikleri son 3 ay içinde gözden geçirildi mi?



JEA, help desk/Tier 2 görevleri için uygulanıyor mu?

Bölüm Özeti

Kimlik bilgisi hijyeni, tek bir aracın değil sürekli bir disiplinin sonucudur. Standing privilege'ı JIT modele dönüştürmek, saldırı penceresini dramatik şekilde daraltan, ölçülebilir etkisi olan az sayıdaki kontrollerden biridir. Protected Users grubu, düşük maliyetle uygulanabilecek, hızlı kazanım sağlayan bir ilk adımdır.

Sahada Dikkat Edilecek Noktalar

- "Kim bu grupta, neden burada" sorusunu düzenli sormayan her ayrıcalıklı grup zamanla şişer.
- PAM/PIM'i "bir gün yaparız" listesinden çıkarıp somut bir proje haline getirin — standing privilege her gün risktir.

Ek Okuma

- Microsoft Learn: "Protected Users Security Group"
- Microsoft Learn: "Just Enough Administration Overview"
- Microsoft Entra PIM dokümantasyonu

Kaynakça

1. Microsoft Learn, *Protected Users Security Group*
2. Microsoft Learn, *Just Enough Administration*
3. Microsoft Learn, *Microsoft Entra Privileged Identity Management*

Bölüm 11 — g/MSA, LAPS, Servis Hesapları

Giriş

Servis hesapları ve yerel yönetici parolaları, AD ortamlarındaki en kalıcı ve en az izlenen kimlik bilgisi kategorileridir. Bu bölüm, Bölüm 4'te değinilen Kerberoasting savunmasının (gMSA) ve Bölüm 3'te değinilen "pass the hash yayılması" riskinin (LAPS) somut uygulamasını ele alır.

Öğrenme Hedefleri

- gMSA/sMSA'nın klasik hizmet hesaplarına göre güvenlik avantajını açıklayabilmek.
- LAPS/Windows LAPS'ın nasıl çalıştığını ve neden zorunlu olması gerektiğini bilmek.
- "Golden gMSA" riskini ve KDS Root Key'in kritik önemini anlamak.

Temel Kavramlar

gMSA (Group Managed Service Account), parolasını AD'nin kendisinin ürettiği, 120 karakter uzunluğunda, 30 günde bir otomatik rotasyona uğrayan, birden fazla sunucu tarafından paylaşılabilen bir hizmet hesabı türüdür. **sMSA (standalone Managed Service Account)** aynı mantığı tek bir sunucuya bağlı olarak uygular.

LAPS (Local Administrator Password Solution), her bilgisayarın yerel Administrator hesabı için **benzersiz, rastgele, otomatik rotasyona uğrayan** bir parola sağlayan çözümdür. Parola, AD'de ilgili bilgisayar objesinin bir özniteliğinde (klasik LAPS: `ms-Mcs-AdmPwd`, Windows LAPS: `msLAPS-Password`) şifreli olarak saklanır ve sadece yetkilendirilmiş hesaplar okuyabilir.

KDS Root Key (Key Distribution Services Root Key), gMSA parolalarının türetildiği temel gizli anahtardır. Bu anahtarı ele geçiren biri, herhangi bir gMSA'nın parolasını **AD'ye hiç dokunmadan, offline olarak** hesaplayabilir — bu teknik "Golden gMSA" olarak adlandırılır.

Teknik Arka Plan

Neden gMSA, Klasik Hizmet Hesabından Güvenlidir

Klasik bir hizmet hesabı, insan tarafından belirlenen ve nadiren değiştirilen bir parolaya sahiptir — bu da Bölüm 4'teki Kerberoasting'in neden bu kadar etkili olduğunun temelidir. gMSA'nın 120 karakterlik, tamamen rastgele parolası, pratik olarak offline brute-force ile kıramaz; ayrıca parola hiçbir insan tarafından bilinmez/yazılmaz, bu da parola paylaşımı/sızıntısı riskini ortadan kaldırır.

LAPS'ın Çözdüğü Sorun: Pass-the-Hash Yayılımı

LAPS olmadan, kurumlar genellikle **tüm** iş istasyonlarında/sunucularda **aynı** yerel Administrator parolasını kullanır (imaj/kurulum sürecinin bir parçası olarak). Bir saldırgan tek bir makinede bu parolanın hash'ini elde ettiğinde, "pass the hash" ile **aynı parolayı paylaşan her makineye** anında yayılabilir. LAPS, her makineye benzersiz bir parola atayarak bu yayılımı **tek bir makineyle sınırlar**.

```
# Windows LAPS parolasını okuma (yetkilendirilmiş hesap)
Get-LapsADPassword -Identity "WKS-001" -AsPlainText
```

Golden gMSA Riski

KDS Root Key, forest genelinde tüm gMSA'ların parolalarının türetildiği kök gizli anahtardır. Bu anahtarı ele geçiren bir saldırgan (tipik olarak bir DC'ye tam erişim gerektirir, dolayısıyla zaten Tier 0 ihlali anlamına gelir), forest'teki **her** gMSA'nın parolasını offline hesaplayabilir — bu, gMSA'nın "Kerberoasting'e dayanıklı" olma avantajını, KDS Root Key düzeyinde bir tehditle dengelenmesi gerektiğini gösterir. Bu senaryo, zaten Tier 0'ı ele geçirmiş bir saldırganın **persistence**'ini güçlendirmesi açısından önemlidir — birincil savunma hattı değil, ikincil bir derinlik katmanıdır.

gMSA/sMSA'ya Geçiş Süreci

```
# gMSA oluşturma (KDS Root Key önceden oluşturulmuş olmalı)
Add-KdsRootKey -EffectiveTime ((Get-Date).AddHours(-10)) # lab/test için; üretimde varsayılan beklen
New-ADServiceAccount -Name "svc-webapp-gmsa" -DNSHostName "webapp.corp.local" `
-PrincipalsAllowedToRetrieveManagedPassword "WebAppServers"
Install-ADServiceAccount -Identity "svc-webapp-gmsa"
```

Riskler ve Tehditler

Saha Gerçekleri

Birçok ortamda hâlâ tüm sunucularda/iş istasyonlarında aynı yerel Administrator parolası kullanılır — bu, "imaj standardizasyonu" pratiklerinin bir yan etkisi olarak ortaya çıkar ve LAPS uygulanmadığı sürece fark edilmez. Kritik uygulamaları çalıştıran hizmet hesaplarının çoğu, uygulamanın "gMSA desteklemediği" varsayımıyla hâlâ klasik parola tabanlı hesaplardır — oysa modern uygulamaların çoğu gMSA'yı destekler, bu varsayım genellikle test edilmemiştir.

Güvenlik Riskleri

- LAPS uygulanmayan ortamlarda, tek bir makinenin ele geçirilmesi domain genelinde yerel admin erişimine dönüşebilir.
- KDS Root Key'in kendisi, Tier 0 hijyeni gerektiren kritik bir varlıktır ve genellikle bu şekilde sınıflandırılmaz.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Lateral Movement: Pass the Hash	T1550.002	LAPS olmadan paylaşılan yerel admin parolası ile yayılım
Steal or Forge Kerberos Tickets: Kerberoasting	T1558.003	Klasik hizmet hesaplarının zayıf parolaları

Teknik	ID	Açıklama
OS Credential Dumping	T1003	KDS Root Key hedefli offline gMSA hesaplama

Savunma Yöntemleri

1. **Windows LAPS'ı tüm sunucu ve iş istasyonlarına dağıtın** (klasik LAPS yerine, Windows Server 2019+/Windows 10 20H2+ için yerleşik).
2. **Mümkün olan her hizmet hesabını gMSA/sMSA'ya taşıyın** — özellikle SPN sahibi, Kerberoasting'e açık hesapları önceliklendirin.
3. **KDS Root Key'i ve gMSA yönetim haklarını Tier 0 olarak sınıflandırın**.
4. **LAPS parolası okuma haklarını sıkı kontrol edin** — sadece gerçekten gerekli olan (örn. help desk için Tier 2 sistemler) rol bazlı erişim tanımlayın, geniş gruplara okuma hakkı vermeyin.
5. **Uygulama envanterini gMSA uyumluluğu açısından yeniden değerlendirin** — "desteklemiyor" varsayımını test ederek doğrulayın.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	Uygulama Sahipleri
Windows LAPS dağıtımı	R	A	I
gMSA geçişi	R	C	A
KDS Root Key Tier 0 sınıflandırması	C	R	I

Standart Eşleştirmesi

- **CIS Benchmark** — yerel yönetici hesabı yönetimi kontrolleri.
- **NIST SP 800-63B** — kimlik bilgisi gücü ve rotasyon gereksinimleri.

Gerçek Dünya Senaryosu: Tek Parola, 3.000 Makine

Bir kurumda, standart imaj sürecinde belirlenen tek bir yerel Administrator parolası, 3.000'den fazla iş istasyonunda **değişmeden** kullanılıyordu. Bir phishing saldırısı sonucu ele geçirilen tek bir iş istasyonundan, saldırgan bu parolanın hash'ini elde etti ve pass-the-hash ile organizasyondaki neredeyse tüm iş istasyonlarına birkaç saat içinde yayıldı. LAPS uygulaması sonrası (üç aylık bir proje), bu yayılım senaryosu teknik olarak imkansız hale geldi — her makine artık benzersiz bir parolaya sahipti. **Ders:** LAPS, uygulama maliyeti düşük, etkisi çok yüksek bir kontroldür; ertelenecek bir proje değildir.

Kontrol Listesi

- ☐ Windows LAPS tüm sunucu/iş istasyonlarına dağıtıldı mı?
- ☐ SPN sahibi hizmet hesapları gMSA/sMSA'ya taşındı mı (mümkün olanlar)?
- ☐ KDS Root Key ve gMSA yönetim hakları Tier 0 olarak sınıflandırıldı mı?
- ☐ LAPS parolası okuma hakları en az yetki ilkesiyle mi tanımlı?
- ☐ Aynı yerel admin parolasını paylaşan makine grubu kaldı mı (denetim)?

Bölüm Özeti

gMSA ve LAPS, uygulama maliyeti görece düşük olan ama etkisi çok yüksek iki kontroldür — biri Kerberoasting yüzeyini pratik olarak ortadan kaldırır, diğeri pass-the-hash yayılımını tek bir makineyle sınırlar. Her iki kontrolün de kendi Tier 0 bağımlılığı (KDS Root Key, LAPS okuma hakları) vardır ve bu bağımlılıklar da aynı titizlikle korunmalıdır.

Sahada Dikkat Edilecek Noktalar

- "Uygulama gMSA desteklemiyor" iddiasını test etmeden kabul etmeyin.
- LAPS'ı sadece sunuculara değil, tüm iş istasyonu filosuna yayın — pass-the-hash yayılımı en çok istasyon seviyesinde gerçekleşir.

Ek Okuma

- Microsoft Learn: "Windows LAPS Overview"
- Microsoft Learn: "Group Managed Service Accounts Overview"
- SpecterOps, "Golden gMSA Trust Attacks"

Kaynakça

1. Microsoft Learn, *Windows LAPS*
2. Microsoft Learn, *Group Managed Service Accounts*
3. SpecterOps, Golden gMSA araştırma yayını

Bölüm 12 — İzleme & Tespit (SIEM/Sigma)

Giriş

Önceki bölümlerde ele alınan her saldırı tekniği, doğru yapılandırılmış izleme ile tespit edilebilir bir iz bırakır. Bu bölüm, önleyici kontrollerin (Bölüm 4-11) yetersiz kaldığı veya atlatıldığı durumlarda son savunma hattı olan tespit katmanını ele alır.

Öğrenme Hedefleri

- AD güvenliği için kritik Event ID kataloğunu bilmek.
- Sigma kurallarının SIEM-agnostik tespit mantığı yazmak için nasıl kullanıldığını anlamak.
- Honeypot/canary hesap stratejisini uygulayabilmek.

Temel Kavramlar

Event ID, Windows olay günlüğündeki her olay türünü tanımlayan sayısal koddur. AD güvenliği için kritik olan Event ID'lerin büyük çoğunluğu **Security** günlüğünde, doğru audit policy (Bölüm 1'de değinilen **AuditMonitoringChecker** kapsamı) etkinleştirildiğinde üretilir.

Sigma, SIEM ürününden bağımsız, YAML tabanlı bir tespit kuralı formatıdır — bir kez yazılan bir Sigma kuralı, Splunk/Elastic/Microsoft Sentinel gibi farklı SIEM'lere dönüştürülebilir (**sigmac** / **sigma-cli** araçlarıyla). Bu, tespit mantığının araç bağımsız, paylaşılabılır ve topluluk tarafından denetlenebilir olmasını sağlar.

Honeypot/Canary hesap, hiçbir meşru kullanım amacı olmayan, sadece "birisi bana dokunursa alarm ver" amacıyla oluşturulan sahte bir AD objesidir (kullanıcı, servis hesabı veya SPN). Bu hesaba yönelik **herhangi bir** etkileşim (Kerberoasting talebi, logon denemesi, ACL sorgusu) yüksek güvenilirlikli bir uyarıdır çünkü meşru hiçbir süreç bu hesaba dokunmamalıdır.

Teknik Arka Plan

Kritik Event ID Kataloğu

Event ID	Açıklama	İlgili Bölüm
4624 / 4625	Başarılı / başarısız oturum açma	Genel, Tier ihlali tespiti (Bölüm 3)
4634	Oturum kapatma	Genel
4648	Açık kimlik bilgisiyle oturum açma (RunAs)	Yanal hareket tespiti
4662	Bir obje üzerinde işlem (doğru SACL ile DCSync tespiti mümkün)	Bölüm 4 (DCSync)

Event ID	Açıklama	İlgili Bölüm
4663	Objeye erişim denemesi	ACL/dosya erişim izleme
4720	Kullanıcı hesabı oluşturuldu	Persistence tespiti
4738	Kullanıcı hesabı değiştirildi	<code>userAccountControl</code> değişiklikleri (Bölüm 1, 4)
4742	Bilgisayar hesabı değiştirildi	RBCD tespiti (Bölüm 7)
4768	TGT talebi (AS-REQ)	AS-REP Roasting tespiti (Bölüm 4)
4769	TGS talebi	Kerberoasting tespiti (Bölüm 4)
4771	Kerberos preauth başarısız	Parola sprengi tespiti
4776	NTLM kimlik doğrulama denemesi	NTLM kullanım izleme
5136	Dizin objesi değiştirildi	GPO/ACL değişiklik izleme (Bölüm 5, 8)
5137	Dizin objesi oluşturuldu	Yeni obje/persistence izleme
5141	Dizin objesi silindi	Persistence temizleme izleme

DCSync Tespiti – Event ID 4662

DCSync'i tespit etmek için, `Replicating Directory Changes` ve `Replicating Directory Changes All` genişletilmiş haklarının kullanımını izleyen bir SACL, domain objesinin kendisine uygulanmalıdır. Bu SACL etkinleştirildiğinde, DC olmayan bir kaynaktan gelen bu hakların kullanımı Event ID 4662 olarak loglanır – kaynak IP/hesap DC listesinde değilse, bu **yüksek güvenilirlikli** bir DCSync uyarısıdır.

Örnek Sigma Kuralı – Kerberoasting Tespiti

```

title: Olası Kerberoasting Aktivitesi
id: 8ac9c67a-b4a2-4f5f-9e7d-example
status: stable
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4769
    TicketEncryptionType: '0x17' # RC4
  filter:
    ServiceName|endswith: '$' # makine hesaplarını hariç tut
timeframe: 5m
condition: selection and not filter | count() by TargetUserName > 15
level: high

```

Honeypot/Canary Stratejisi

Etkili bir canary hesap stratejisi, saldırganın recon aşamasında ("yüksek değerli hedef görünen ama aslında tuzak olan" bir hesap) yakalanmasını sağlar:

- SPN'i olan, "eski/unutulmuş görünen" isimli (`svc_legacy_backup` gibi) ama gerçekte hiçbir yerde kullanılmayan bir canary hizmet hesabı oluşturun — bu hesaba yönelik herhangi bir Kerberoasting talebi (Event ID 4769) doğrudan alarm üretmelidir.
- `adminCount=1` görünen ama gerçekte hiçbir ayrıcalıklı gruba üye olmayan bir "sahte ayrıcalıklı" hesap, BloodHound taramalarında saldırganın dikkatini çekecek şekilde tasarlanabilir.

Riskler ve Tehditler

Saha Gerçekleri

Çoğu kurumda audit policy varsayılan (minimal) ayarlarda kalır çünkü "log hacmi çok fazla olur, depolama maliyeti artar" endişesi vardır. Bu, Bölüm 2'de değinilen "breakout time küçük, tespit süresi büyük" sorununun doğrudan nedenidir.

Güvenlik Riskleri

- Doğru audit policy olmadan, önceki bölümlerde tanımlanan hiçbir tespit kuralı çalışmaz — önlem (Bölüm 4-11) ile tespit (bu bölüm) birbirini tamamlamalıdır, biri diğerinin yerini tutmaz.
- SIEM'e yüksek hacimli ama düşük sinyal/gürültü oranlı loglar gönderilmesi, gerçek uyarıların kaybolmasına (alert fatigue) yol açar.

MITRE ATT&CK Eşleştirmesi

Bu bölüm, önceki bölümlerde listelenen tüm tekniklerin **Detection** katmanını temsil eder — MITRE ATT&CK'in her tekniği için "Detection" bölümünde önerilen veri kaynakları (Windows Event Logs, Authentication Logs) bu bölümdeki Event ID kataloğuyla doğrudan örtüşür.

Savunma Yöntemleri

1. **Advanced Audit Policy'yi doğru yapılandırın** — özellikle "Audit Kerberos Service Ticket Operations", "Audit Directory Service Access", "Audit Directory Service Changes" alt kategorilerini etkinleştirin.
2. **Domain objesine DCSync SACL'i uygulayın** ve Event ID 4662'yi DC olmayan kaynaklar için filtreleyin.
3. **Sigma kural setini (SigmaHQ topluluğu) SIEM'inize entegre edin** — AD'ye özel kuralları önceliklendirin (Kerberoasting, DCSync, Golden Ticket, GPO değişikliği).
4. **En az 2-3 canary hesap/SPN oluşturun** ve bunlara yönelik herhangi bir aktiviteyi en yüksek öncelikli uyarı olarak yapılandırın.
5. **Log saklama süresini adli analiz ihtiyacına göre belirleyin** — özellikle Golden Ticket gibi uzun süreli persistence tekniklerinin tespiti için en az 90 gün önerilir.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	SOC	AD Yöneticisi	CISO
Audit policy yapılandırma	C	R	I
Sigma kural entegrasyonu	R	C	I
Canary hesap tasarımı/izleme	R	C	I

Standart Eşleştirmesi

- **NIST SP 800-92** — Log Management Guide.
- **CIS Controls v8** — Control 8 (Audit Log Management).

Gerçek Dünya Senaryosu: Sessiz Kerberoasting

Bir kurumda, aylık ortalama 50.000 Event ID 4769 üretiliyordu ve hiçbirisi incelenmiyordu çünkü SIEM'de bu olay türü için bir kural yoktu. Bir sızma testi sırasında, test ekibinin ürettiği anormal yoğunluktaki Kerberoasting talepleri (aynı kaynak host'tan 5 dakikada 40+ TGS talebi) hiçbir uyarı tetiklemedi. Sigma tabanlı bir Kerberoasting kuralı devreye alındıktan sonra yapılan aynı testte, uyarı 90 saniye içinde SOC'a ulaştı. **Ders:** Log toplamak tespit etmek anlamına gelmez — doğru kural olmadan log, sadece depolama maliyetidir.

Kontrol Listesi

- ☐ Advanced Audit Policy AD güvenliği için gerekli tüm alt kategorilerde etkin mi?
- ☐ DCSync tespiti için domain objesine SACL uygulandı mı?
- ☐ Kerberoasting/AS-REP Roasting/Golden Ticket için Sigma kuralları SIEM'e entegre mi?
- ☐ En az 2-3 canary hesap/SPN aktif ve izleniyor mu?
- ☐ Log saklama süresi en az 90 gün mü?
- ☐ SOC, bu bölümdeki Event ID'lerin her biri için bir yanıt prosedürüne sahip mi?

Bölüm Özeti

İzleme, önleyici kontrollerin başarısız olduğu veya atlatıldığı anlarda devreye giren son savunma hattıdır. Doğru audit policy ve Sigma tabanlı kurallar olmadan, önceki bölümlerdeki hiçbir teknik savunma "görünür" olmaz — önlem ve tespit birlikte çalışmalıdır.

Sahada Dikkat Edilecek Noktalar

- "Logluyoruz" ile "tespit ediyoruz" farklı şeylerdir — kural yoksa tespit yoktur.
- Canary hesaplar, düşük maliyetli ama yüksek sinyal/gürültü oranlı en iyi erken uyarı mekanizmalarından biridir.

Ek Okuma

- SigmaHQ GitHub deposu (topluluk tespit kuralları)
- Microsoft Learn: "Advanced Security Audit Policy Settings"

Kaynakça

1. SigmaHQ, *Sigma Rules Repository*
2. Microsoft Learn, *Advanced Security Audit Policy Settings*
3. MITRE ATT&CK, Detection alanı (her teknik için)

Bölüm 13 — Backup & Felaket Kurtarma

Giriş

Önleme ve tespit ne kadar iyi olursa olsun, "AD tamamen ele geçirildi" senaryosuna hazırlıklı olmak zorunludur — çünkü fidye yazılımı operasyonlarının çoğu tam olarak bu sonucu hedefler. Bu bölüm, KRBTGT rotasyon prosedürünü (Bölüm 4'te tanıtılan) detaylandırır ve forest recovery planlamasını ele alır.

Öğrenme Hedefleri

- AD'ye özgü yedekleme stratejisini (System State, forest recovery) tanımlayabilmek.
- KRBTGT parola rotasyon prosedürünü doğru sırayla uygulayabilmek.
- Forest recovery planının neden düzenli tatbikat gerektirdiğini açıklayabilmek.

Temel Kavramlar

System State Backup, bir DC'nin AD veritabanını (`ntds.dit`), SYSVOL'u, registry'yi ve diğer sistem bileşenlerini içeren, DC'yi bütün olarak geri yükleyebilen yedekleme türüdür.

Authoritative vs Non-Authoritative Restore: Non-authoritative restore, geri yüklenen DC'nin diğer DC'lerden replikasyonla güncel hale gelmesini sağlar (tekil bir DC'nin çökmesi durumunda kullanılır).

Authoritative restore, geri yüklenen verinin diğer tüm DC'lere **zorla** yayılmasını sağlar — bu, kasıtlı bir silme/bozulma sonrası (örn. saldırgan tarafından silinen objelerin geri getirilmesi) gereklidir.

Forest Recovery, tüm forest'in (tüm DC'lerin) sıfırdan, belgelenmiş bir prosedürle yeniden inşa edilmesi senaryosudur — genellikle bir ransomware operasyonu sonrası, mevcut forest'e artık güvenilemediği (saldırganın hâlâ persistence mekanizmalarına sahip olabileceği) durumlarda uygulanır.

Teknik Arka Plan

KRBTGT Parola Rotasyon Prosedürü

KRBTGT hesabının parolası, AD'nin kendi mekanizmalarıyla asla otomatik rotasyona uğramaz — bu, birçok ortamda kurulumdan beri hiç değişmemiş olmasının nedenidir. Rotasyon, Microsoft'un sağladığı `New-KrbtgtKeys.ps1` betiği veya manuel `Set-ADAccountPassword` ile yapılabilir, ancak **kritik bir kural** vardır: KRBTGT'nin geçmiş **iki** parolası da (mevcut + bir önceki) geçerli kabul edilir, bu yüzden **tek seferlik** bir rotasyon, saldırganın hâlâ eski parolayla üretilmiş bir Golden Ticket kullanmasına izin verebilir.

Doğru prosedür (şüpheli bir olay sonrası, "reset" niteliğinde): 1. Tüm DC'lerin sağlıklı replikasyon durumunda olduğunu doğrulayın (`repadmin /replsummary`). 2. KRBTGT parolasını **ilk kez** sıfırlayın ve replikasyonun tüm DC'lere yayılmasını bekleyin (replikasyon topolojinize göre birkaç saat). 3. **En az 10 saat bekleyin** (varsayılan maksimum TGT ömrü ~10 saat) — bu bekleme, ilk rotasyon öncesi üretilmiş TGT'lerin doğal olarak süresinin dolmasını sağlar. 4. KRBTGT parolasını **ikinci kez** sıfırlayın ve yine replikasyonun tamamlanmasını bekleyin.

```
# Microsoft'un resmi betiği (indirilip test ortamında doğrulanmalı)
.\New-KrbtgtKeys.ps1 -TargetDomain corp.local -Mode Both -Scope DomainOnly
```

Bu iki aşamalı prosedür atlanırsa (örn. acele ile tek seferlik reset yapılırsa), saldırganın elindeki Golden Ticket'lar rotasyon sonrası bile **bir süre daha** geçerliliğini koruyabilir — bu, KRBTGT rotasyonunun "olay müdahalesi" (incident response) sürecinde en sık yanlış uygulanan adımlarından biridir.

Forest Recovery Planlaması

Microsoft'un "Forest Recovery Guide"ı, bir forest'in sıfırdan güvenli şekilde yeniden inşası için sıralı bir prosedür tanımlar: en son bilinen temiz System State yedeğinden ilk DC'nin (genellikle bir FSMO rolü sahibi) izole bir ağda geri yüklenmesi, KRBTGT'nin **iki kez** sıfırlanması (yukarıdaki prosedür), tüm bilgisayar hesabı parolalarının sıfırlanması, ardından diğer DC'lerin bu temiz DC'den yeniden kurulması (geri yükleme değil, temiz kurulum + replikasyon).

Tabletop Tatbikat

Forest recovery planı, yılda en az bir kez **kağıt üzerinde (tabletop)** ve mümkünse izole bir lab ortamında **fiilen** test edilmelidir. Test edilmemiş bir recovery planı, gerçek bir olayda genellikle beklenenden çok daha uzun sürer ve öngörülemeyen engellerle karşılaşır (örn. yedeklerin de saldırgan tarafından silinmiş/şifrelenmiş olması).

Riskler ve Tehditler

Saha Gerçekleri

Birçok kurumda "AD yedekleniyor" denildiğinde kastedilen, sanal makine seviyesinde snapshot'lardır — bu snapshot'lar genellikle DC'nin bulunduğu aynı sanallaştırma altyapısında saklanır ve bir ransomware operasyonu hypervisor'ı da etkilerse **bu yedekler de kaybedilir**.

Güvenlik Riskleri

- Offline/immutable (değiştirilemez) yedek kopyası olmayan bir AD ortamı, ransomware karşısında "yedekten dönemeyiz" durumuna düşer.
- Test edilmemiş forest recovery planı, kağıt üzerinde var olur ama gerçek bir olayda güvenilir değildir.
- KRBTGT'nin sadece bir kez sıfırlanması, "rotasyon yaptık" yanılgısı yaratır ama saldırgana kalıcı erişim bırakabilir.

MITRE ATT&CK Eşleştirmesi

Teknik	ID	Açıklama
Data Encrypted for Impact	T1486	Ransomware'in nihai etkisi — recovery planının tetiklendiği senaryo
Inhibit System Recovery	T1490	Saldırganların yedekleri hedef alması

Teknik	ID	Açıklama
Steal or Forge Kerberos Tickets: Golden Ticket	T1558.001	Tek aşamalı KRBTGT rotasyonunun eksik bıraktığı risk

Savunma Yöntemleri

1. **Offline/immutable yedekleme uygulayın** — DC yedeklerinin en az bir kopyası, üretim ağından ve hypervisor'dan izole (air-gapped veya immutable storage) olmalıdır.
2. **KRBTGT rotasyonunu iki aşamalı, doğru zamanlamayla uygulayın** (yukarıdaki prosedür) — özellikle her şüpheli olay sonrası ve yılda en az bir kez rutin olarak.
3. **Forest recovery planını yazılı, güncel ve erişilebilir tutun** — planın kendisi de, saldırganın erişemeyeceği bir yerde (örn. offline, farklı bir kimlik altyapısında) saklanmalıdır.
4. **Yılda en az bir kez tabletop, mümkünse lab ortamında fiili tatbikat yapın.**
5. **Yedekleme altyapısını Tier 0 olarak sınıflandırın** (Bölüm 3'te değinildiği gibi) — yedekleme yazılımının kendisi DC'lere erişebiliyorsa, bu yazılımı yöneten herkes Tier 0 yetkisine sahiptir.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO	İş Sürekliliği Ekibi
Offline yedekleme stratejisi	R	C	A	C
KRBTGT rotasyon prosedürü	R	A	I	I
Forest recovery tatbikatı	R	C	A	R

Standart Eşleştirmesi

- **NIST SP 800-34** — Contingency Planning Guide.
- **ISO 22301** — İş Sürekliliği Yönetim Sistemi.

Gerçek Dünya Senaryosu: Yedekler de Şifrelendi

Bir kurum, bir ransomware saldırısı sonrası AD'yi yedekten geri yüklemeye çalıştığında, yedekleme sunucusunun da (aynı ağda, aynı Domain Admin kimlik bilgileriyle yönetildiği için) saldırgan tarafından ele geçirilip yedeklerin şifrelendiğini/silindiğini keşfetti. Kurum, sıfırdan bir forest kurmak zorunda kaldı; bu süreç, test edilmemiş bir planla **3 hafta** sürdü ve iş kaybı milyonlarca dolara ulaştı. **Ders:** Yedekleme altyapısı, yedeklediği sistemle aynı ayrıcalık alanında olmamalıdır (Tier 0 izolasyonu burada da geçerlidir); recovery planı test edilmeden "var" sayılmamalıdır.

Kontrol Listesi

- ☐ En az bir offline/immutable DC yedeği var mı?
- ☐ Yedekleme altyapısı Tier 0 olarak sınıflandırıldı ve izole mi?
- ☐ KRBTGT rotasyon prosedürü belgeli ve iki aşamalı mı?
- ☐ Forest recovery planı yazılı, güncel ve saldırganın erişemeyeceği bir yerde mi saklanıyor?
- ☐ Son 12 ay içinde tabletop veya fiili recovery tatbikatı yapıldı mı?

Bölüm Özeti

Backup ve felaket kurtarma, "hiçbir zaman kullanılmaması umulan ama mutlaka hazır olması gereken" son savunma katmanıdır. KRBTGT'nin iki aşamalı rotasyonu ve yedekleme altyapısının Tier 0 izolasyonu, bu bölümün en kritik iki teknik gereksinimidir — ikisi de test edilmeden "tamamlandı" sayılmamalıdır.

Sahada Dikkat Edilecek Noktalar

- "Yedekliyoruz" ile "geri yükleyebiliyoruz" arasındaki fark, sadece tatbikatla ortaya çıkar.
- KRBTGT rotasyonunu acele ile tek seferde yapmayın — iki aşamalı prosedür atlanırsa amacına ulaşmaz.

Ek Okuma

- Microsoft, "AD Forest Recovery Guide"
- Microsoft Learn: "KRBTGT Account Password Reset Scripts"

Kaynakça

1. Microsoft, *Active Directory Forest Recovery Guide*
2. Microsoft Learn, *AD DS: KRBTGT Account Password Reset Scripts*
3. NIST SP 800-34, *Contingency Planning Guide for Federal Information Systems*

Bölüm 14 — Olgunluk Yol Haritası (Zero-to-Hero)

Giriş

Bu son bölüm, önceki 13 bölümde ele alınan tüm kontrolleri tek bir **olgunluk modeli** ve **uygulanabilir zaman çizelgesi** içinde birleştirir. Amaç, "nereden başlamalıyım" sorusuna somut bir cevap vermektir — çünkü bu rehberin tamamını aynı anda uygulamaya çalışmak, hiçbirini uygulamamaktan daha az etkili olabilir.

Öğrenme Hedefleri

- Kendi ortamınızın olgunluk seviyesini (0-4 arası) objektif olarak değerlendirebilmek.
- Yüksek etki / düşük çaba kontrolleri önce uygulama mantığını benimseyebilmek.
- 30-60-90 günlük somut bir aksiyon planı çıkarabilmek.

Temel Kavramlar

Olgunluk modeli, bir kurumun AD güvenliği açısından hangi aşamada olduğunu 0'dan (Zero — hiçbir temel kontrol yok) 4'e (Hero — sürekli iyileştirme kültürü yerleşmiş) kadar sınıflandıran bir çerçevedir. Her seviye, bir öncekinin **önkoşuludur** — Tier Modeli'ni uygulamadan (Seviye 2) izleme olgunluğuna (Seviye 3) geçmeye çalışmak, temelsiz bir yapı kurmak anlamına gelir.

Yüksek etki / düşük çaba (quick win) ilkesi: Sınırlı kaynaklarla çalışan çoğu kurum için, en yüksek risk azaltımını en düşük operasyonel maliyetle sağlayan kontroller (LAPS, KRBTGT rotasyonu, **ms-DS-MachineAccountQuota** sıfırlama, SYSVOL **cpassword** taraması) her zaman önceliklidir — büyük mimari değişiklikler (Tier Modeli, PAM/PIM) daha fazla zaman ve organizasyonel değişim gerektirir.

Teknik Arka Plan

Olgunluk Seviyeleri

Seviye	Ad	Karakteristik
0 — Zero	Temel hijyen yok	LAPS yok, KRBTGT hiç rotasyona uğramamış, SYSVOL'da temizlenmemiş cpassword , herkes Domain Admin
1 — Farkındalık	Riskler biliniyor ama sistematik kapatılmamış	Bir BloodHound taraması yapılmış ama bulgular kapatılmamış, envanterler eksik
2 — Yapılandırılmış	Tier Modeli kısmen uygulanmış	Tier 0 tanımlı, PAW kısmen var, ama teknik olarak zorunlu kılınmıyor (istisnalar var)
3 — Zorunlu Kılınmış	Teknik kontroller istisnasız uygulanıyor	Authentication Policy Silos aktif, PAM/PIM devrede, gMSA/LAPS tam kapsamda
4 — Hero		

Seviye	Ad	Karakteristik
	Sürekli iyileştirme + tespit + tatbikat kültürü	Düzenli purple team, canary hesaplar, test edilmiş forest recovery, SIEM'de AD'ye özel Sigma kuralları

Bölmelerin Olgunluk Seviyeleriyle Eşleştirilmesi

Bölüm	Ait Olduğu Minimum Seviye
1 (AD Temelleri), 11 (gMSA/LAPS)	Seviye 1
4 (Kerberos), 5 (ACL), 7 (Delegasyon), 8 (GPO) – temel hijyen kısımları	Seviye 1-2
3 (Tier Modeli), 10 (PAM/JIT)	Seviye 2-3
6 (ADCS), 9 (Trust) – derinlemesine denetim	Seviye 2-3
12 (İzleme), 13 (Backup/Recovery tatbikatı)	Seviye 3-4

30-60-90 Günlük Aksiyon Planı (Seviye 0-1'den Başlayan Kurumlar İçin)

İlk 30 gün – Quick Win'ler (düşük çaba, yüksek etki): - SYSVOL'da **cpassword** taraması ve temizliği (Bölüm 8). - **ms-DS-MachineAccountQuota** değerini 0'a düşürme (Bölüm 7). - Kerberoasting/AS-REP Roasting'e açık hesap envanteri (Bölüm 4). - Windows LAPS'ı en kritik sunucu grubuna (örn. DC'lere komşu sunucular) dağıtma başlangıcı (Bölüm 11). - KRBTGT parolasının ne zaman değiştiğini kontrol etme; 1 yıldan eskiyse iki aşamalı rotasyon planlama (Bölüm 13).

31-60 gün – Yapısal Temeller: - İlk BloodHound (savunma amaçlı) taraması ve en kritik ACL zincirlerinin kapatılması (Bölüm 5). - Tier 0 varlık envanterinin çıkarılması (Bölüm 3) – DC'ler dışındaki kaçırılan varlıklar dahil. - Unconstrained Delegation'ın tamamen kaldırılması (Bölüm 7). - AD CS varsa ESC1/ESC8 taraması ve acil kapatma (Bölüm 6). - Advanced Audit Policy'nin doğru yapılandırılması (Bölüm 12).

61-90 gün – Tier Modeli'nin İlk Aşaması: - Tier 0 için PAW politikasının teknik olarak zorunlu kılınması (Authentication Policy Silo veya en azından GPO logon rights, Bölüm 3). - Ayrıcalıklı grup üyeliklerinin gözden geçirilmesi ve standing privilege'ın azaltılması (Bölüm 10). - İlk Sigma kurallarının (Kerberoasting, DCSync) SIEM'e entegrasyonu (Bölüm 12). - Trust envanteri ve SID filtering doğrulaması (Bölüm 9).

90 gün sonrası – Sürekli Program: - PAM/PIM projesinin tamamlanması, JIT modeline geçiş (Bölüm 10). - gMSA geçişinin genişletilmesi, tüm iş istasyonu filosuna LAPS dağıtımı (Bölüm 11). - Yıllık forest recovery tatbikatı takvimi (Bölüm 13). - Yıllık purple team egzersizi takvimi (Bölüm 2). - Canary hesap stratejisinin devreye alınması (Bölüm 12).

Riskler ve Tehditler

Saha Gerçekleri

Birçok kurum, olgunluk yolculuğuna doğru sırayla değil, "en son duyduğumuz tehdit" önceliğiyle başlar – bu, bazı alanlarda ileri seviye kontroller uygulanırken temel hijyenin (Seviye 0-1) hâlâ eksik kalmasına yol

açar. Örneğin, gelişmiş bir SIEM kurulumu (Seviye 3-4 karakteristiği) varken KRBTGT hiç rotasyona uğramamış (Seviye 0 açığı) olabilir.

Güvenlik Riskleri

- Temelsiz ilerleme (Seviye 0-1 atlanarak Seviye 3 araçlarına yatırım), yanlış güvenlik hissi yaratır.
- Tek seferlik bir "proje" olarak ele alınan Tier Modeli, uygulandıktan sonra bakımsız kalırsa zamanla yeniden Seviye 1-2'ye geriler (Tier 0 sprawl, Bölüm 3).

Savunma Yöntemleri (Olgunluk İlerletme Stratejisi)

1. **Kendi seviyenizi objektif olarak değerlendirin** — bu bölümdeki kontrol listesini (aşağıda) mevcut ortamınıza uygulayarak başlayın, varsayımla değil.
2. **Sırayı atlamayın** — Seviye 2 (Tier Modeli) olmadan Seviye 3 (zorunlu kılma) anlamsızdır.
3. **Quick win'leri ilk 30 günde bitirin** — bu, hem gerçek risk azaltımı sağlar hem de organizasyonel momentum yaratır.
4. **Olgunluğu bir proje değil, sürekli bir program olarak yönetin** — yıllık gözden geçirme takvimine bağlayın.

Kurumsal Uygulama Önerileri

Kurumsal Rol ve Sorumluluk Matrisi (RACI Özeti)

Aktivite	AD Yöneticisi	Güvenlik Ekibi	CISO
Olgunluk seviyesi değerlendirmesi	C	R	A
30-60-90 gün planı uygulama	R	C	A
Yıllık program gözden geçirme	C	R	A

Standart Eşleştirmesi

- **NIST Cybersecurity Framework** — olgunluk modeli genel çerçevesi.
- **CIS Controls Implementation Groups (IG1/IG2/IG3)** — kaynak bazlı önceliklendirme mantığı, bu bölümdeki quick win yaklaşımıyla örtüşür.

Gerçek Dünya Senaryosu: 90 Günde Seviye 0'dan Seviye 2'ye

Orta ölçekli bir kurum, bir sızma testi sonrası Domain Admin'e 4 saatte ulaşılabildiğini öğrendiğinde Seviye 0'daydı: KRBTGT 9 yıldır değişmemiş, LAPS yok, Unconstrained Delegation üç sunucuda aktifti. Bu rehberdeki 30-60-90 planını uygulayarak, 90 gün sonunda: SYSVOL temizlendi, `ms-DS-MachineAccountQuota` sıfırlandı, KRBTGT iki aşamalı rotasyona uğradı, Unconstrained Delegation kaldırıldı, Tier 0 envanteri çıkarıldı ve PAW politikası GPO ile zorunlu kılındı. Takip sızma testinde, aynı ekip Domain Admin'e ulaşamadı; en iyi elde edebildikleri Tier 1 sunucu erişimiydi. **Ders:** Doğru sırayla uygulanan temel kontroller, 90 gün gibi kısa bir sürede ölçülebilir, doğrulanabilir bir fark yaratabilir.

Kontrol Listesi — Genel Olgunluk Öz Değerlendirmesi

□

Seviye 1: SYSVOL temiz, KRBTGT güncel, temel hijyen kontrolleri mevcut mu?

□

Seviye 2: Tier 0 envanteri eksiksiz, OU yapısı Tier'a hizalı, PAW tanımlı mı (henüz zorunlu olmasa da)?

□

Seviye 3: PAW/Tier sınırları teknik kontrollerle (Authentication Policy Silo) zorunlu mu, PAM/PIM devrede mi, gMSA/LAPS tam kapsamda mı?

□

Seviye 4: SIEM'de AD'ye özel Sigma kuralları aktif mi, canary hesaplar var mı, yıllık purple team/forest recovery tatbikatı yapılıyor mu?

Bölüm Özeti

Bu rehberdeki 14 bölüm, tek seferlik bir kontrol listesi değil, sıralı bir olgunluk yolculuğudur. Tier Modeli (Bölüm 3) merkezde durur; ondan önceki bölümler (1-2, 4-9, 11) bu modelin neden gerekli olduğunu ve hangi saldırı yüzeyini kapattığını gösterir, ondan sonraki bölümler (10, 12-13) modeli operasyonel olarak sürdürülebilir kılar. "Zero to Hero" burada bir slogan değil, somut, ölçülebilir ve sıralı bir ilerleme planıdır.

Sahada Dikkat Edilecek Noktalar

- En gelişmiş SIEM kuralı bile, temel hijyen (KRBTGT, LAPS, MachineAccountQuota) eksikse eksik bir savunmayı telafi edemez.
- Olgunluk bir varış noktası değil, sürekli korunması gereken bir durumdur — bakımsız bırakılan her kontrol zamanla geriler.

Ek Okuma

- Microsoft Learn: "Privileged Access Strategy" (bu rehberin genel çerçevesiyle örtüşür)
- CIS Controls v8, Implementation Groups

Kaynakça

1. Microsoft Learn, *Privileged Access Strategy*
 2. CIS Controls v8, *Implementation Groups*
 3. NIST Cybersecurity Framework 2.0
-

Kapanış

Bu el kitabı, Active Directory güvenliğini sıfırdan uzmanlığa taşıyan, Tier Modeli merkezli bir referans olarak tasarlandı. On dört bölümün her biri bağımsız olarak okunabilir, ancak gerçek değer, bölümler arasındaki bağlantıların (Kerberos'un Tier Modeli'ne, ACL'in delegasyona, izlemenin her saldırı türüne bağlanması gibi) anlaşılmasında ortaya çıkar.

Bir sonraki adım: Bölüm 14'teki 30-60-90 günlük planı kendi ortamınıza uygulayın, sonuçları ölçün ve bu rehberi kurumunuzun kendi bulgu kataloğuyla (AD Guard gibi bir denetim aracının çıktılarıyla) zenginleştirin.

Bu rehber, yetkili güvenlik testleri ve savunma amaçlı kullanım için hazırlanmıştır. Sürüm 1.0.

Uğur KARAKOÇ – Senior Cyber Security Expert